

Threat model report for FRX

Owner:

Unassigned

Reviewer:

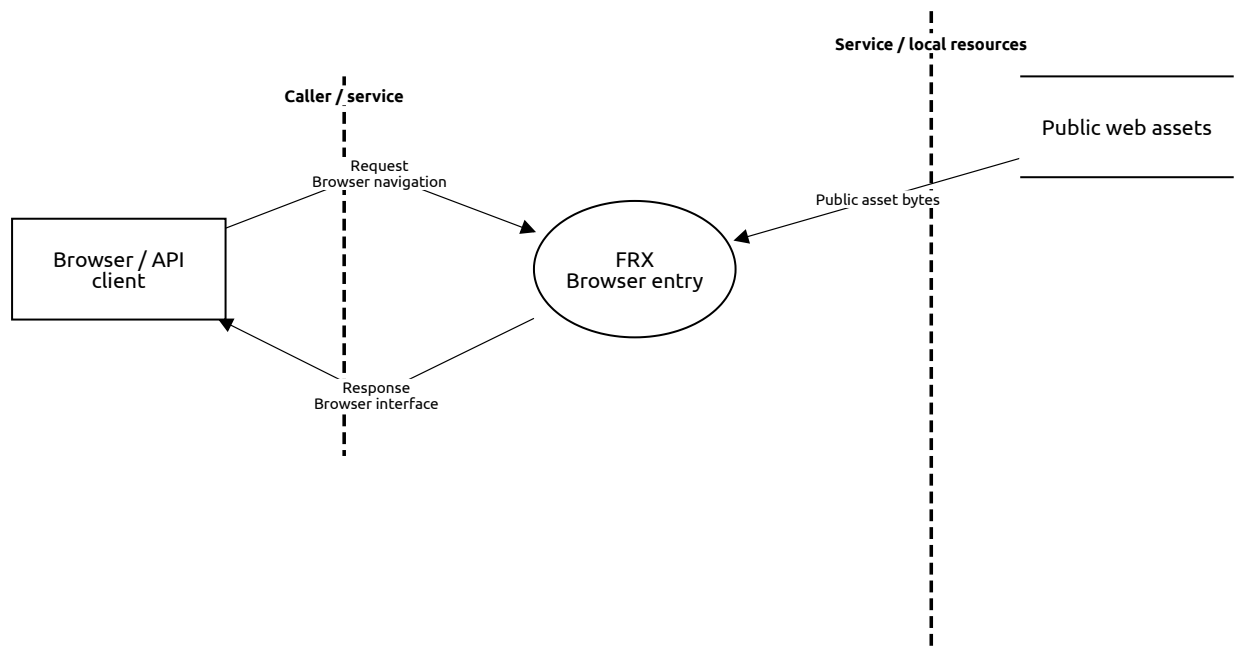
Review pending

Contributors:

High level system description

FRX requirements and architecture threat model. Scope: local portal, browser/API users, identity/report storage, standalone document intake, event logging and a local analytics provider. Threats are planning scenarios, not verified code findings. Existing controls are limited to explicitly identified architecture constraints; other controls are proposals. Requirement and assumption identifiers are defined in requirements-and-architecture.md. No risk acceptance or production-readiness claim is made.

01 FRX GET /



Request Browser navigation (Data Flow)

Description:

Caller inputs cross the service boundary. Authority must be established independently of supplied identifiers. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Repeated requests exhaust service capacity

Denial of service, Open, Low Priority

Description:

Preconditions: A caller can repeatedly reach this interface; normal protected operations require a session. Assets: Local service availability. Consequences: Request work could delay report review, especially when file, database or provider work shares capacity. Architecture constraints: Loopback exposure and bounded portal request bodies limit some inputs; rate limits and capacity guarantees are unverified. Basis: REQ-04, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define request/concurrency budgets and ensure advisory-provider failure does not prevent report review. Verification plan: Use an agreed bounded load profile and provider-failure scenarios. Owner and disposition: unassigned; review pending.

Response Browser interface (Data Flow)

Description:

Return the endpoint result or error. An acknowledgement does not imply an out-of-scope workflow. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Public content or service response substituted

Tampering, Open, Low Priority

Description:

Preconditions: An attacker controls the local endpoint, delivery path or content source. Assets: Page, asset, status or metric integrity. Consequences: Altered content could mislead users or change browser behavior. Architecture constraints: Local-only service exposure; public responses are intentionally nonsecret. Host and delivery integrity are unverified. Basis: ARC-01, ARC-03, ARC-06, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Protect content publication and service identity; validate external responses before use. Verification plan: Review content-write permissions and test substituted responses in a disposable environment. Owner and disposition: unassigned; review pending.

Public asset bytes (Data Flow)

Description:

Read public browser assets if present. This is not upload retrieval. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Stored content altered outside the request policy

Tampering, Open, Medium Priority

Description:

Preconditions: An attacker has write access to this local resource. Assets: Public web assets. Consequences: Changes could corrupt reports, intake, browser assets or audit evidence, depending on the resource. Architecture constraints: Local storage is part of the architecture; separate permissions or protection zones are not assumed. Basis: REQ-02, REQ-03, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Restrict writes to authorized functions, protect published assets and verify integrity/recovery controls. Verification plan: Review access rights and test unauthorized modification and recovery. Owner and disposition: unassigned; review pending.

Browser / API client (External Actor)

Description:

Untrusted local caller. Partner, analyst and administrator roles matter where authenticated authority is required. Public operations accept anonymous callers. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

No threats listed.

FRX Browser entry (Process)

Description:

Serve the browser interface; subsequent API interactions have their own diagrams. Basis: ARC-01, ARC-06 STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Repeated requests exhaust service capacity

Denial of service, Open, Low Priority

Description:

Preconditions: A caller can repeatedly reach this interface; normal protected operations require a session. Assets: Local service availability. Consequences: Request work could delay report review, especially when file, database or provider work shares capacity. Architecture constraints: Loopback exposure and bounded portal request bodies limit some inputs; rate limits and capacity guarantees are unverified. Basis: REQ-04, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define request/concurrency budgets and ensure advisory-provider failure does not prevent report review. Verification plan: Use an agreed bounded load profile and provider-failure scenarios. Owner and disposition: unassigned; review pending.

Public web assets (Data Store)

Description:

Local resource accessed directly by FRX; no independently enforced storage zone is asserted. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Stored content altered outside the request policy

Tampering, Open, Medium Priority

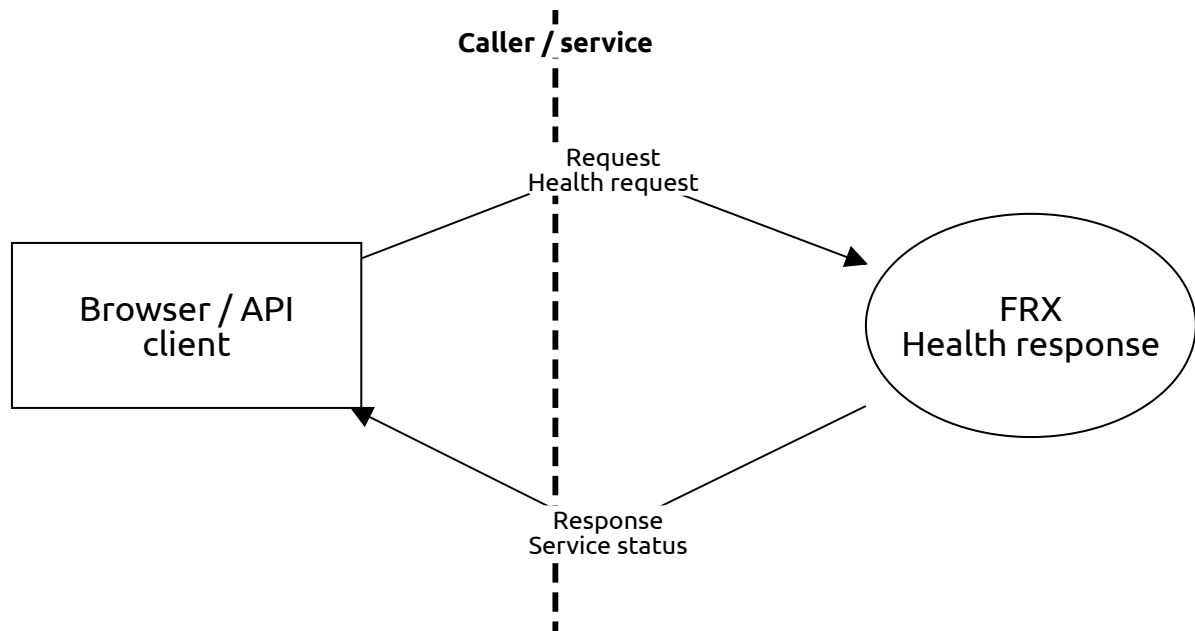
Description:

Preconditions: An attacker has write access to this local resource. Assets: Public web assets. Consequences: Changes could corrupt reports, intake, browser assets or audit evidence, depending on the resource. Architecture constraints: Local storage is part of the architecture; separate permissions or protection zones are not assumed. Basis: REQ-02, REQ-03, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Restrict writes to authorized functions, protect published assets and verify integrity/recovery controls. Verification plan: Review access rights and test unauthorized modification and recovery. Owner and disposition: unassigned; review pending.

02 FRX GET /health



Request Health request (Data Flow)

Description:

Caller inputs cross the service boundary. Authority must be established independently of supplied identifiers. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Repeated requests exhaust service capacity

Denial of service, Open, Low Priority

Description:

Preconditions: A caller can repeatedly reach this interface; normal protected operations require a session. Assets: Local service availability. Consequences: Request work could delay report review, especially when file, database or provider work shares capacity. Architecture constraints: Loopback exposure and bounded portal request bodies limit some inputs; rate limits and capacity guarantees are unverified. Basis: REQ-04, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define request/concurrency budgets and ensure advisory-provider failure does not prevent report review. Verification plan: Use an agreed bounded load profile and provider-failure scenarios. Owner and disposition: unassigned; review pending.

Response Service status (Data Flow)

Description:

Return the endpoint result or error. An acknowledgement does not imply an out-of-scope workflow. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Public content or service response substituted

Tampering, Open, Low Priority

Description:

Preconditions: An attacker controls the local endpoint, delivery path or content source. Assets: Page, asset, status or metric integrity. Consequences: Altered content could mislead users or change browser behavior. Architecture constraints: Local-only service exposure; public responses are intentionally nonsecret. Host and delivery integrity are unverified. Basis: ARC-01, ARC-03, ARC-06, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Protect content publication and service identity; validate external responses before use. Verification plan: Review content-write permissions and test substituted responses in a disposable environment. Owner and disposition: unassigned; review pending.

Browser / API client (External Actor)

Description:

Untrusted local caller. Partner, analyst and administrator roles matter where authenticated authority is required. Public operations accept anonymous callers. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

No threats listed.

FRX Health response (Process)

Description:

Return public service status, without a business-data lookup. Basis: ARC-06 STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Repeated requests exhaust service capacity

Denial of service, Open, Low Priority

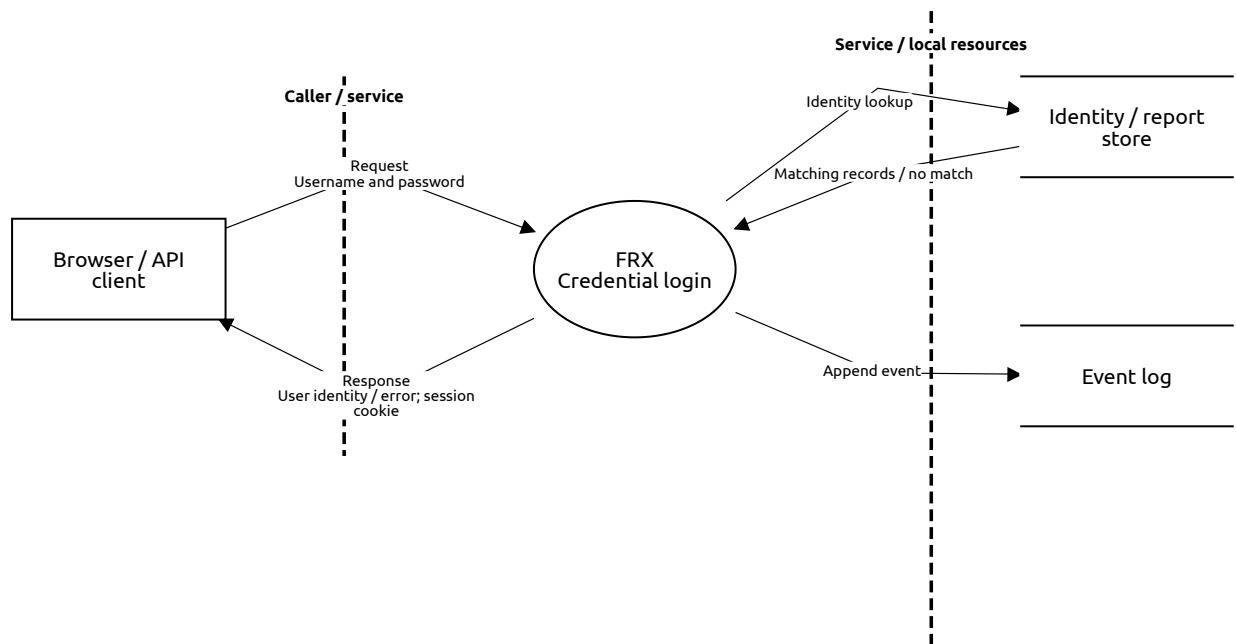
Description:

Preconditions: A caller can repeatedly reach this interface; normal protected operations require a session. Assets: Local service availability. Consequences: Request work could delay report review, especially when file, database or provider work shares capacity. Architecture constraints: Loopback exposure and bounded portal request bodies limit some inputs; rate limits and capacity guarantees are unverified. Basis: REQ-04, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define request/concurrency budgets and ensure advisory-provider failure does not prevent report review. Verification plan: Use an agreed bounded load profile and provider-failure scenarios. Owner and disposition: unassigned; review pending.

03 FRX POST /login



Request Username and password (Data Flow)

Description:

Caller inputs cross the service boundary. Authority must be established independently of supplied identifiers. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: Applicable: attached scenario. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Sensitive request or response observed in transit

Information disclosure, Open, Medium Priority

Description:

Preconditions: An attacker can observe local traffic or impersonate the service endpoint. Assets: Credentials, session cookies and report data. Consequences: Observed data could disclose reports or permit account/session misuse. Architecture constraints: Loopback limits reach; authenticated encrypted transport is not established by this planning baseline. Basis: REQ-02, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define transport confidentiality and endpoint-authentication controls and verify client trust. Verification plan: Inspect permitted protocols and certificate validation using a controlled local client. Owner and disposition: unassigned; review pending.

Response User identity / error; session cookie (Data Flow)

Description:

Return the endpoint result or error. An acknowledgement does not imply an out-of-scope workflow. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: Applicable: attached scenario. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Sensitive request or response observed in transit

Information disclosure, Open, Medium Priority

Description:

Preconditions: An attacker can observe local traffic or impersonate the service endpoint. Assets: Credentials, session cookies and report data. Consequences: Observed data could disclose reports or permit account/session misuse. Architecture constraints: Loopback limits reach; authenticated encrypted transport is not established by this planning baseline. Basis: REQ-02, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define transport confidentiality and endpoint-authentication controls and verify client trust. Verification plan: Inspect permitted protocols and certificate validation using a controlled local client. Owner and disposition: unassigned; review pending.

Identity lookup (Data Flow)

Description:

Local database read; authorization and query safety are separate decisions. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Stored content altered outside the request policy

Tampering, Open, Medium Priority

Description:

Preconditions: An attacker has write access to this local resource. Assets: Identity / report store. Consequences: Changes could corrupt reports, intake, browser assets or audit evidence, depending on the resource. Architecture constraints: Local storage is part of the architecture; separate permissions or protection zones are not assumed. Basis: REQ-02, REQ-03, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Restrict writes to authorized functions, protect published assets and verify integrity/recovery controls. Verification plan: Review access rights and test unauthorized modification and recovery. Owner and disposition: unassigned; review pending.

Matching records / no match (Data Flow)

Description:

Record contents enter request-processing memory. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: Applicable: attached scenario. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Stored data read by an unintended principal

Information disclosure, Open, Medium Priority

Description:

Preconditions: An attacker can read local files or an unprotected copy. Assets: Identity / report store. Consequences: Sensitive records or credentials could be exposed. Architecture constraints: Synthetic data is used locally; permissions, encryption and backup protection require confirmation. Basis: REQ-02, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Apply least-privilege access and appropriate encryption/backup controls. Verification plan: Review permitted readers, copies and key custody. Owner and disposition: unassigned; review pending.

Append event (Data Flow)

Description:

Persistent side effect; write failures can affect request completion. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Stored content altered outside the request policy

Tampering, Open, Medium Priority

Description:

Preconditions: An attacker has write access to this local resource. Assets: Event log. Consequences: Changes could corrupt reports, intake, browser assets or audit evidence, depending on the resource. Architecture constraints: Local storage is part of the architecture; separate permissions or protection zones are not assumed. Basis: REQ-02, REQ-03, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Restrict writes to authorized functions, protect published assets and verify integrity/recovery controls. Verification plan: Review access rights and test unauthorized modification and recovery. Owner and disposition: unassigned; review pending.

Browser / API client (External Actor)

Description:

Untrusted local caller. Partner, analyst and administrator roles matter where authenticated authority is required. Public operations accept anonymous callers. STRIDE applicability: Spoofing: Applicable: attached scenario. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Forged or replayed session identity

Spoofing, Open, High Priority

Description:

Preconditions: An attacker obtains a session cookie or gains knowledge of its signing key. Assets: User identity and role authority. Consequences: The attacker could act as another user, including a privileged user. Architecture constraints: Credential login and signed cookies are part of the architecture; key custody, expiry and revocation are unverified. Basis: REQ-01, REQ-02, ARC-02, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Protect and rotate signing keys, constrain cookie use and lifetime, and define revocation and identity revalidation. Verification plan: Attempt altered and replayed cookies, including after logout and account disablement. Owner and disposition: unassigned; review pending.

FRX Credential login (Process)

Description:

Look up identity, verify credentials, issue a session and record selected login events. Basis: REQ-02, REQ-05, ARC-02 STRIDE applicability: Spoofing: Applicable: attached scenario. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: Applicable: attached scenario. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Repeated requests exhaust service capacity

Denial of service, Open, Low Priority

Description:

Preconditions: A caller can repeatedly reach this interface; normal protected operations require a session. Assets: Local service availability. Consequences: Request work could delay report review, especially when file, database or provider work shares capacity. Architecture constraints: Loopback exposure and bounded portal request bodies limit some inputs; rate limits and capacity guarantees are unverified. Basis: REQ-04, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define request/concurrency budgets and ensure advisory-provider failure does not prevent report review. Verification plan: Use an agreed bounded load profile and provider-failure scenarios. Owner and disposition: unassigned; review pending.

Credential input subverts identity lookup

Spoofing, Open, High Priority

Description:

Preconditions: A caller controls login fields. Assets: Identity and account authority. Consequences: If input changes the credential query or verification decision, an attacker could obtain another identity. Architecture constraints: Credential verification is an intended decision point; query separation and failure behavior require verification. Basis: REQ-02, ARC-02. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Keep user input separate from query structure; validate input and enforce account eligibility. Verification plan: Exercise malformed credentials and query-control characters; verify no session is issued on failure. Owner and disposition: unassigned; review pending.

Credentials exposed through storage, logs or errors

Information disclosure, Open, High Priority

Description:

Preconditions: An attacker can read identity storage, event records or diagnostic responses. Assets: Passwords and account identifiers. Consequences: Plaintext or weakly protected credentials could support account takeover. Architecture constraints: Identity storage and login events exist; credential protection and secret redaction are not assumed. Basis: REQ-02, REQ-05, ARC-02. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Use appropriate password protection, restrict storage access and omit secrets from events and responses. Verification plan: Review credential-storage protection and inspect successful/failed login records for secrets. Owner and disposition: unassigned; review pending.

Repeated password guessing

Spoofing, Open, Medium Priority

Description:

Preconditions: A caller can repeatedly reach login. Assets: Account identity. Consequences: Unrestricted guesses could discover a usable credential. Architecture constraints: Loopback exposure limits reach; throttling and lockout are unverified. Basis: REQ-02, ARC-02. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define rate limits, abuse detection and recovery behavior that resists account lockout abuse. Verification plan: Test a bounded series of failed logins and legitimate recovery. Owner and disposition: unassigned; review pending.

Browser submits an unintended operation

Tampering, Open, Medium Priority

Description:

Preconditions: A hostile page induces a browser request and relevant cookies or login fields are accepted. Assets: User intent and request integrity. Consequences: An unwanted login, logout, intake or inspection request could run in the user context. Architecture constraints: Cookie-associated workflows are in scope; origin validation and anti-forgery protections are unverified. Basis: REQ-02, ARC-02. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define origin and anti-forgery controls for browser operations, including session transitions. Verification plan: Exercise cross-site submissions in a controlled browser and verify intended user actions still work. Owner and disposition: unassigned; review pending.

Identity / report store (Data Store)

Description:

Local resource accessed directly by FRX; no independently enforced storage zone is asserted. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: Applicable: attached scenario. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Stored content altered outside the request policy

Tampering, Open, Medium Priority

Description:

Preconditions: An attacker has write access to this local resource. Assets: Identity / report store. Consequences: Changes could corrupt reports, intake, browser assets or audit evidence, depending on the resource. Architecture constraints: Local storage is part of the architecture; separate permissions or protection zones are not assumed. Basis: REQ-02, REQ-03, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Restrict writes to authorized functions, protect published assets and verify integrity/recovery controls. Verification plan: Review access rights and test unauthorized modification and recovery. Owner and disposition: unassigned; review pending.

Stored data read by an unintended principal

Information disclosure, Open, Medium Priority

Description:

Preconditions: An attacker can read local files or an unprotected copy. Assets: Identity / report store. Consequences: Sensitive records or credentials could be exposed. Architecture constraints: Synthetic data is used locally; permissions, encryption and backup protection require confirmation. Basis: REQ-02, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Apply least-privilege access and appropriate encryption/backup controls. Verification plan: Review permitted readers, copies and key custody. Owner and disposition: unassigned; review pending.

Storage loss or unavailability interrupts work

Denial of service, Open, Medium Priority

Description:

Preconditions: Storage fills, fails, is locked or is removed. Assets: Identity / report store. Consequences: Reports, intake or event records could become unavailable or be lost. Architecture constraints: No recovery assurance is established by the architecture. Basis: REQ-03, REQ-04, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define storage budgets and recovery objectives; demonstrate consistent restoration. Verification plan: Perform bounded capacity and restore exercises using disposable data. Owner and disposition: unassigned; review pending.

Event log (Data Store)

Description:

Local resource accessed directly by FRX; no independently enforced storage zone is asserted. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: Applicable: attached scenario. Information disclosure: Applicable: attached scenario. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Stored content altered outside the request policy

Tampering, Open, Medium Priority

Description:

Preconditions: An attacker has write access to this local resource. Assets: Event log. Consequences: Changes could corrupt reports, intake, browser assets or audit evidence, depending on the resource. Architecture constraints: Local storage is part of the architecture; separate permissions or protection zones are not assumed. Basis: REQ-02, REQ-03, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Restrict writes to authorized functions, protect published assets and verify integrity/recovery controls. Verification plan: Review access rights and test unauthorized modification and recovery. Owner and disposition: unassigned; review pending.

Stored data read by an unintended principal

Information disclosure, Open, Medium Priority

Description:

Preconditions: An attacker can read local files or an unprotected copy. Assets: Event log. Consequences: Sensitive records or credentials could be exposed. Architecture constraints: Synthetic data is used locally; permissions, encryption and backup protection require confirmation. Basis: REQ-02, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Apply least-privilege access and appropriate encryption/backup controls. Verification plan: Review permitted readers, copies and key custody. Owner and disposition: unassigned; review pending.

Storage loss or unavailability interrupts work

Denial of service, Open, Medium Priority

Description:

Preconditions: Storage fills, fails, is locked or is removed. Assets: Event log. Consequences: Reports, intake or event records could become unavailable or be lost. Architecture constraints: No recovery assurance is established by the architecture. Basis: REQ-03, REQ-04, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define storage budgets and recovery objectives; demonstrate consistent restoration. Verification plan: Perform bounded capacity and restore exercises using disposable data. Owner and disposition: unassigned; review pending.

Activity cannot be reliably reconstructed

Repudiation, Open, Medium Priority

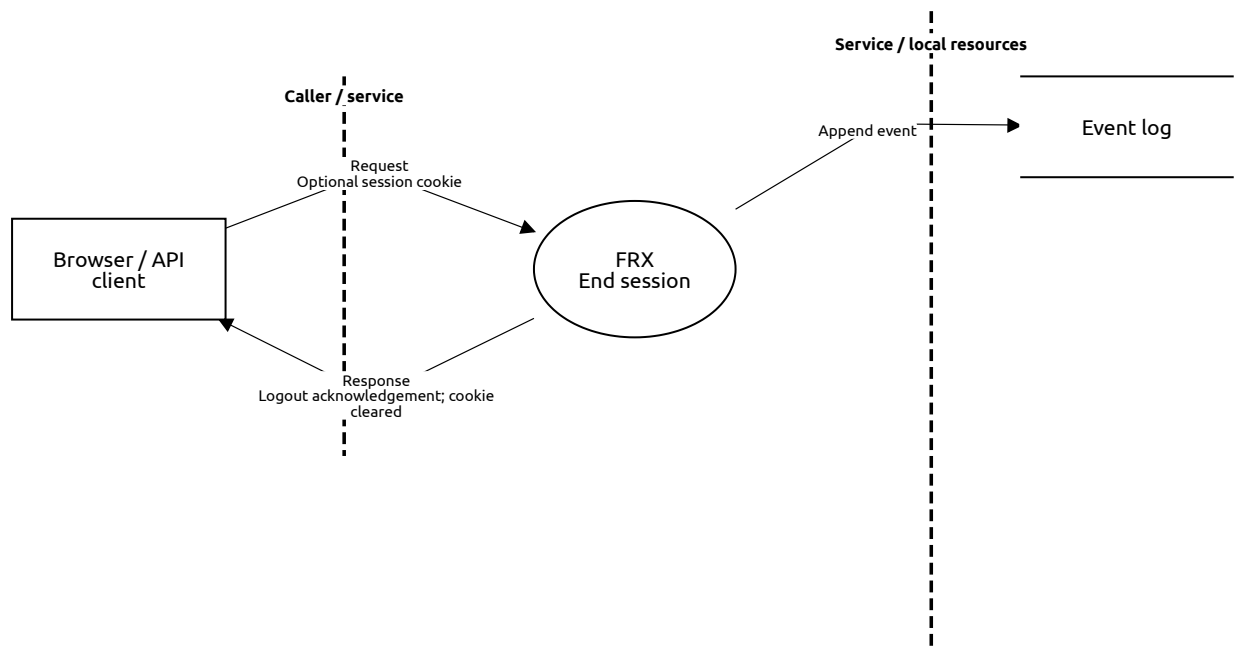
Description:

Preconditions: A caller disputes an action, or an attacker can omit, forge or alter event records. Assets: Event attribution and integrity. Consequences: Reviewers could be unable to establish who accessed data or changed intake. Architecture constraints: Selected actions append local events; completeness, timestamps, escaping and tamper protection are unverified. Basis: REQ-05, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define required events; record actor, action, outcome, time and correlation safely, and protect retention. Verification plan: Reconcile successful and rejected requests with events; test hostile field values and log access controls. Owner and disposition: unassigned; review pending.

04 FRX POST /logout



Request Optional session cookie (Data Flow)

Description:

Caller inputs cross the service boundary. Authority must be established independently of supplied identifiers. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: Applicable: attached scenario. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Sensitive request or response observed in transit

Information disclosure, Open, Medium Priority

Description:

Preconditions: An attacker can observe local traffic or impersonate the service endpoint. Assets: Credentials, session cookies and report data. Consequences: Observed data could disclose reports or permit account/session misuse. Architecture constraints: Loopback limits reach; authenticated encrypted transport is not established by this planning baseline. Basis: REQ-02, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define transport confidentiality and endpoint-authentication controls and verify client trust. Verification plan: Inspect permitted protocols and certificate validation using a controlled local client. Owner and disposition: unassigned; review pending.

Response Logout acknowledgement; cookie cleared (Data Flow)

Description:

Return the endpoint result or error. An acknowledgement does not imply an out-of-scope workflow. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: Applicable: attached scenario. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Sensitive request or response observed in transit

Information disclosure, Open, Medium Priority

Description:

Preconditions: An attacker can observe local traffic or impersonate the service endpoint. Assets: Credentials, session cookies and report data. Consequences: Observed data could disclose reports or permit account/session misuse. Architecture constraints: Loopback limits reach; authenticated encrypted transport is not established by this planning baseline. Basis: REQ-02, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define transport confidentiality and endpoint-authentication controls and verify client trust. Verification plan: Inspect permitted protocols and certificate validation using a controlled local client. Owner and disposition: unassigned; review pending.

Append event (Data Flow)

Description:

Persistent side effect; write failures can affect request completion. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Stored content altered outside the request policy

Tampering, Open, Medium Priority

Description:

Preconditions: An attacker has write access to this local resource. Assets: Event log. Consequences: Changes could corrupt reports, intake, browser assets or audit evidence, depending on the resource. Architecture constraints: Local storage is part of the architecture; separate permissions or protection zones are not assumed. Basis: REQ-02, REQ-03, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Restrict writes to authorized functions, protect published assets and verify integrity/recovery controls. Verification plan: Review access rights and test unauthorized modification and recovery. Owner and disposition: unassigned; review pending.

Browser / API client (External Actor)

Description:

Untrusted local caller. Partner, analyst and administrator roles matter where authenticated authority is required. Public operations accept anonymous callers. STRIDE applicability: Spoofing: Applicable: attached scenario. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Forged or replayed session identity

Spoofing, Open, High Priority

Description:

Preconditions: An attacker obtains a session cookie or gains knowledge of its signing key. Assets: User identity and role authority. Consequences: The attacker could act as another user, including a privileged user. Architecture constraints: Credential login and signed cookies are part of the architecture; key custody, expiry and revocation are unverified. Basis: REQ-01, REQ-02, ARC-02, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Protect and rotate signing keys, constrain cookie use and lifetime, and define revocation and identity revalidation. Verification plan: Attempt altered and replayed cookies, including after logout and account disablement. Owner and disposition: unassigned; review pending.

FRX End session (Process)

Description:

Clear the caller session and record a logout event. An authenticated caller is not required. Basis: ARC-02, REQ-05 STRIDE applicability: Spoofing: Applicable: attached scenario. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Repeated requests exhaust service capacity

Denial of service, Open, Low Priority

Description:

Preconditions: A caller can repeatedly reach this interface; normal protected operations require a session. Assets: Local service availability. Consequences: Request work could delay report review, especially when file, database or provider work shares capacity. Architecture constraints: Loopback exposure and bounded portal request bodies limit some inputs; rate limits and capacity guarantees are unverified. Basis: REQ-04, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define request/concurrency budgets and ensure advisory-provider failure does not prevent report review. Verification plan: Use an agreed bounded load profile and provider-failure scenarios. Owner and disposition: unassigned; review pending.

Copied session survives logout

Spoofing, Open, Medium Priority

Description:

Preconditions: An attacker already holds a copied valid cookie. Assets: Session termination. Consequences: Clearing the browser cookie alone might not revoke the copied credential. Architecture constraints: Client session clearing is in scope; server-enforced revocation is unverified. Basis: REQ-02, ARC-02. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define logout invalidation, expiry and a mechanism to revoke stolen sessions. Verification plan: Replay a copied cookie after logout against a protected operation. Owner and disposition: unassigned; review pending.

Browser submits an unintended operation

Description:

Preconditions: A hostile page induces a browser request and relevant cookies or login fields are accepted. Assets: User intent and request integrity. Consequences: An unwanted login, logout, intake or inspection request could run in the user context. Architecture constraints: Cookie-associated workflows are in scope; origin validation and anti-forgery protections are unverified. Basis: REQ-02, ARC-02. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define origin and anti-forgery controls for browser operations, including session transitions. Verification plan: Exercise cross-site submissions in a controlled browser and verify intended user actions still work. Owner and disposition: unassigned; review pending.

Event log (Data Store)

Description:

Local resource accessed directly by FRX; no independently enforced storage zone is asserted. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: Applicable: attached scenario. Information disclosure: Applicable: attached scenario. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Stored content altered outside the request policy

Tampering, Open, Medium Priority

Description:

Preconditions: An attacker has write access to this local resource. Assets: Event log. Consequences: Changes could corrupt reports, intake, browser assets or audit evidence, depending on the resource. Architecture constraints: Local storage is part of the architecture; separate permissions or protection zones are not assumed. Basis: REQ-02, REQ-03, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Restrict writes to authorized functions, protect published assets and verify integrity/recovery controls. Verification plan: Review access rights and test unauthorized modification and recovery. Owner and disposition: unassigned; review pending.

Stored data read by an unintended principal

Information disclosure, Open, Medium Priority

Description:

Preconditions: An attacker can read local files or an unprotected copy. Assets: Event log. Consequences: Sensitive records or credentials could be exposed. Architecture constraints: Synthetic data is used locally; permissions, encryption and backup protection require confirmation. Basis: REQ-02, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Apply least-privilege access and appropriate encryption/backup controls. Verification plan: Review permitted readers, copies and key custody. Owner and disposition: unassigned; review pending.

Storage loss or unavailability interrupts work

Denial of service, Open, Medium Priority

Description:

Preconditions: Storage fills, fails, is locked or is removed. Assets: Event log. Consequences: Reports, intake or event records could become unavailable or be lost. Architecture constraints: No recovery assurance is established by the architecture. Basis: REQ-03, REQ-04, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define storage budgets and recovery objectives; demonstrate consistent restoration. Verification plan: Perform bounded capacity and restore exercises using disposable data. Owner and disposition: unassigned; review pending.

Activity cannot be reliably reconstructed

Repudiation, Open, Medium Priority

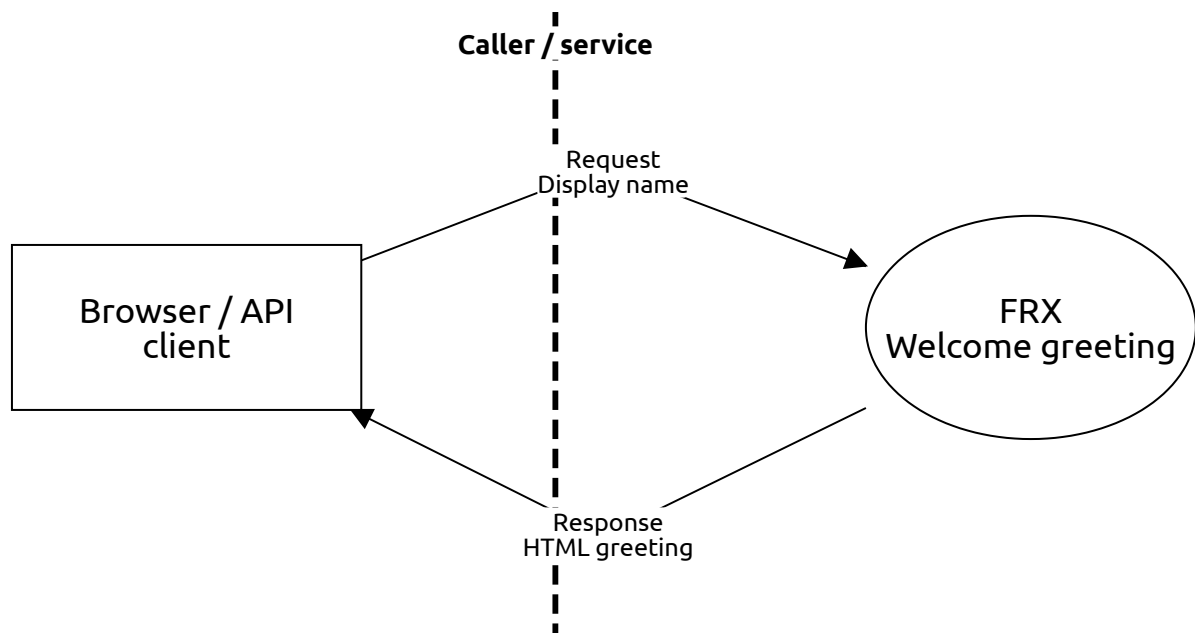
Description:

Preconditions: A caller disputes an action, or an attacker can omit, forge or alter event records. Assets: Event attribution and integrity. Consequences: Reviewers could be unable to establish who accessed data or changed intake. Architecture constraints: Selected actions append local events; completeness, timestamps, escaping and tamper protection are unverified. Basis: REQ-05, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define required events; record actor, action, outcome, time and correlation safely, and protect retention. Verification plan: Reconcile successful and rejected requests with events; test hostile field values and log access controls. Owner and disposition: unassigned; review pending.

05 FRX GET /welcome



Request Display name (Data Flow)

Description:

Caller inputs cross the service boundary. Authority must be established independently of supplied identifiers. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Repeated requests exhaust service capacity

Denial of service, Open, Low Priority

Description:

Preconditions: A caller can repeatedly reach this interface; normal protected operations require a session. Assets: Local service availability. Consequences: Request work could delay report review, especially when file, database or provider work shares capacity. Architecture constraints: Loopback exposure and bounded portal request bodies limit some inputs; rate limits and capacity guarantees are unverified. Basis: REQ-04, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define request/concurrency budgets and ensure advisory-provider failure does not prevent report review. Verification plan: Use an agreed bounded load profile and provider-failure scenarios. Owner and disposition: unassigned; review pending.

Response HTML greeting (Data Flow)

Description:

Return the endpoint result or error. An acknowledgement does not imply an out-of-scope workflow. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Public content or service response substituted

Tampering, Open, Low Priority

Description:

Preconditions: An attacker controls the local endpoint, delivery path or content source. Assets: Page, asset, status or metric integrity. Consequences: Altered content could mislead users or change browser behavior. Architecture constraints: Local-only service exposure; public responses are intentionally nonsecret. Host and delivery integrity are unverified. Basis: ARC-01, ARC-03, ARC-06, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Protect content publication and service identity; validate external responses before use. Verification plan: Review content-write permissions and test substituted responses in a disposable environment. Owner and disposition: unassigned; review pending.

Browser / API client (External Actor)

Description:

Untrusted local caller. Partner, analyst and administrator roles matter where authenticated authority is required. Public operations accept anonymous callers. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

No threats listed.

FRX Welcome greeting (Process)

Description:

Include a caller-supplied display name in a public greeting. Basis: ARC-06 STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Repeated requests exhaust service capacity

Denial of service, Open, Low Priority

Description:

Preconditions: A caller can repeatedly reach this interface; normal protected operations require a session. Assets: Local service availability. Consequences: Request work could delay report review, especially when file, database or provider work shares capacity. Architecture constraints: Loopback exposure and bounded portal request bodies limit some inputs; rate limits and capacity guarantees are unverified. Basis: REQ-04, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define request/concurrency budgets and ensure advisory-provider failure does not prevent report review. Verification plan: Use an agreed bounded load profile and provider-failure scenarios. Owner and disposition: unassigned; review pending.

Untrusted greeting changes browser content

Tampering, Open, High Priority

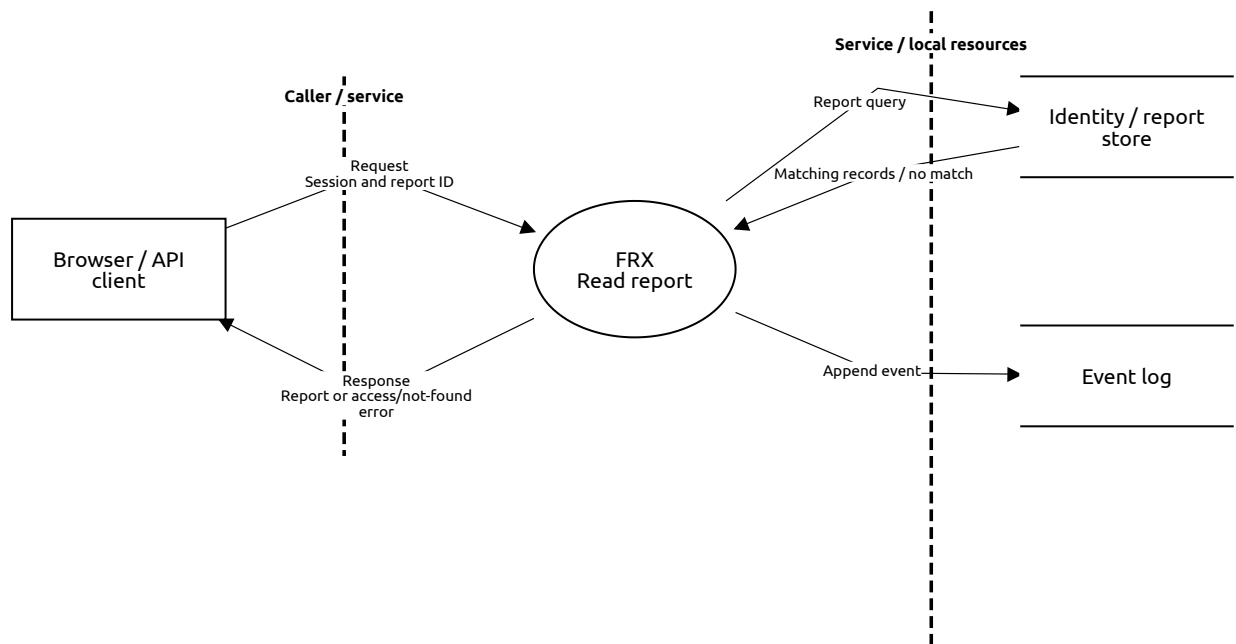
Description:

Preconditions: A user follows a crafted greeting URL. Assets: Browser content and origin authority. Consequences: If output is not contextually encoded, markup or script could run with the portal origin. Architecture constraints: This is a public HTML interface; contextual encoding is a verification question. Basis: REQ-02, ARC-06. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Encode untrusted values for their output context and apply a suitable content policy. Verification plan: Submit markup and script-like display names and inspect browser interpretation. Owner and disposition: unassigned; review pending.

06 FRX GET /reports/<int:report_id>



Request Session and report ID (Data Flow)

Description:

Caller inputs cross the service boundary. Authority must be established independently of supplied identifiers. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: Applicable: attached scenario. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Sensitive request or response observed in transit

Information disclosure, Open, Medium Priority

Description:

Preconditions: An attacker can observe local traffic or impersonate the service endpoint. Assets: Credentials, session cookies and report data. Consequences: Observed data could disclose reports or permit account/session misuse. Architecture constraints: Loopback limits reach; authenticated encrypted transport is not established by this planning baseline. Basis: REQ-02, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define transport confidentiality and endpoint-authentication controls and verify client trust. Verification plan: Inspect permitted protocols and certificate validation using a controlled local client. Owner and disposition: unassigned; review pending.

Response Report or access/not-found error (Data Flow)

Description:

Return the endpoint result or error. An acknowledgement does not imply an out-of-scope workflow. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: Applicable: attached scenario. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Sensitive request or response observed in transit

Information disclosure, Open, Medium Priority

Description:

Preconditions: An attacker can observe local traffic or impersonate the service endpoint. Assets: Credentials, session cookies and report data. Consequences: Observed data could disclose reports or permit account/session misuse. Architecture constraints: Loopback limits reach; authenticated encrypted transport is not established by this planning baseline. Basis: REQ-02, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define transport confidentiality and endpoint-authentication controls and verify client trust. Verification plan: Inspect permitted protocols and certificate validation using a controlled local client. Owner and disposition: unassigned; review pending.

Report query (Data Flow)

Description:

Local database read; authorization and query safety are separate decisions. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Stored content altered outside the request policy

Tampering, Open, Medium Priority

Description:

Preconditions: An attacker has write access to this local resource. Assets: Identity / report store. Consequences: Changes could corrupt reports, intake, browser assets or audit evidence, depending on the resource. Architecture constraints: Local storage is part of the architecture; separate permissions or protection zones are not assumed. Basis: REQ-02, REQ-03, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Restrict writes to authorized functions, protect published assets and verify integrity/recovery controls. Verification plan: Review access rights and test unauthorized modification and recovery. Owner and disposition: unassigned; review pending.

Matching records / no match (Data Flow)

Description:

Record contents enter request-processing memory. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: Applicable: attached scenario. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Stored data read by an unintended principal

Information disclosure, Open, Medium Priority

Description:

Preconditions: An attacker can read local files or an unprotected copy. Assets: Identity / report store. Consequences: Sensitive records or credentials could be exposed. Architecture constraints: Synthetic data is used locally; permissions, encryption and backup protection require confirmation. Basis: REQ-02, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Apply least-privilege access and appropriate encryption/backup controls. Verification plan: Review permitted readers, copies and key custody. Owner and disposition: unassigned; review pending.

Append event (Data Flow)

Description:

Persistent side effect; write failures can affect request completion. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Stored content altered outside the request policy

Tampering, Open, Medium Priority

Description:

Preconditions: An attacker has write access to this local resource. Assets: Event log. Consequences: Changes could corrupt reports, intake, browser assets or audit evidence, depending on the resource. Architecture constraints: Local storage is part of the architecture; separate permissions or protection zones are not assumed. Basis: REQ-02, REQ-03, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Restrict writes to authorized functions, protect published assets and verify integrity/recovery controls. Verification plan: Review access rights and test unauthorized modification and recovery. Owner and disposition: unassigned; review pending.

Browser / API client (External Actor)

Description:

Untrusted local caller. Partner, analyst and administrator roles matter where authenticated authority is required. Public operations accept anonymous callers. STRIDE applicability: Spoofing: Applicable: attached scenario. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Forged or replayed session identity

Spoofing, Open, High Priority

Description:

Preconditions: An attacker obtains a session cookie or gains knowledge of its signing key. Assets: User identity and role authority. Consequences: The attacker could act as another user, including a privileged user. Architecture constraints: Credential login and signed cookies are part of the architecture; key custody, expiry and revocation are unverified. Basis: REQ-01, REQ-02, ARC-02, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Protect and rotate signing keys, constrain cookie use and lifetime, and define revocation and identity revalidation. Verification plan: Attempt altered and replayed cookies, including after logout and account disablement. Owner and disposition: unassigned; review pending.

FRX Read report (Process)

Description:

Retrieve an existing report and record selected read events. Required access depends on ownership, assignment or authorized administrator role. Basis: REQ-01, REQ-05, ARC-02
STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: Applicable: attached scenario. Elevation of privilege: Applicable: attached scenario.

Repeated requests exhaust service capacity

Denial of service, Open, Medium Priority

Description:

Preconditions: A caller can repeatedly reach this interface; normal protected operations require a session. Assets: Local service availability. Consequences: Request work could delay report review, especially when file, database or provider work shares capacity. Architecture constraints: Loopback exposure and bounded portal request bodies limit some inputs; rate limits and capacity guarantees are unverified. Basis: REQ-04, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define request/concurrency budgets and ensure advisory-provider failure does not prevent report review. Verification plan: Use an agreed bounded load profile and provider-failure scenarios. Owner and disposition: unassigned; review pending.

Report identifier crosses ownership authority

Elevation of privilege, Open, High Priority

Description:

Preconditions: A signed-in user chooses a report outside their permitted set. Assets: Report access authority. Consequences: Authentication without a report-specific decision could grant unauthorized report access and disclosure. Architecture constraints: A session is required; an integer identifier is not evidence of authorization. Basis: REQ-01, ARC-02. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Apply ownership, assignment and role checks to every report access. Verification plan: Test every role against owned, assigned, unrelated and missing reports. Owner and disposition: unassigned; review pending.

Identity / report store (Data Store)

Description:

Local resource accessed directly by FRX; no independently enforced storage zone is asserted. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: Applicable: attached scenario. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Stored content altered outside the request policy

Tampering, Open, Medium Priority

Description:

Preconditions: An attacker has write access to this local resource. Assets: Identity / report store. Consequences: Changes could corrupt reports, intake, browser assets or audit evidence, depending on the resource. Architecture constraints: Local storage is part of the architecture; separate permissions or protection zones are not assumed. Basis: REQ-02, REQ-03, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Restrict writes to authorized functions, protect published assets and verify integrity/recovery controls. Verification plan: Review access rights and test unauthorized modification and recovery. Owner and disposition: unassigned; review pending.

Stored data read by an unintended principal

Information disclosure, Open, Medium Priority

Description:

Preconditions: An attacker can read local files or an unprotected copy. Assets: Identity / report store. Consequences: Sensitive records or credentials could be exposed. Architecture constraints: Synthetic data is used locally; permissions, encryption and backup protection require confirmation. Basis: REQ-02, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Apply least-privilege access and appropriate encryption/backup controls. Verification plan: Review permitted readers, copies and key custody. Owner and disposition: unassigned; review pending.

Storage loss or unavailability interrupts work

Denial of service, Open, Medium Priority

Description:

Preconditions: Storage fills, fails, is locked or is removed. Assets: Identity / report store. Consequences: Reports, intake or event records could become unavailable or be lost. Architecture constraints: No recovery assurance is established by the architecture. Basis: REQ-03, REQ-04, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define storage budgets and recovery objectives; demonstrate consistent restoration. Verification plan: Perform bounded capacity and restore exercises using disposable data. Owner and disposition: unassigned; review pending.

Event log (Data Store)

Description:

Local resource accessed directly by FRX; no independently enforced storage zone is asserted. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: Applicable: attached scenario. Information disclosure: Applicable: attached scenario. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Stored content altered outside the request policy

Tampering, Open, Medium Priority

Description:

Preconditions: An attacker has write access to this local resource. Assets: Event log. Consequences: Changes could corrupt reports, intake, browser assets or audit evidence, depending on the resource. Architecture constraints: Local storage is part of the architecture; separate permissions or protection zones are not assumed. Basis: REQ-02, REQ-03, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Restrict writes to authorized functions, protect published assets and verify integrity/recovery controls. Verification plan: Review access rights and test unauthorized modification and recovery. Owner and disposition: unassigned; review pending.

Stored data read by an unintended principal

Information disclosure, Open, Medium Priority

Description:

Preconditions: An attacker can read local files or an unprotected copy. Assets: Event log. Consequences: Sensitive records or credentials could be exposed. Architecture constraints: Synthetic data is used locally; permissions, encryption and backup protection require confirmation. Basis: REQ-02, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Apply least-privilege access and appropriate encryption/backup controls. Verification plan: Review permitted readers, copies and key custody. Owner and disposition: unassigned; review pending.

Storage loss or unavailability interrupts work

Denial of service, Open, Medium Priority

Description:

Preconditions: Storage fills, fails, is locked or is removed. Assets: Event log. Consequences: Reports, intake or event records could become unavailable or be lost. Architecture constraints: No recovery assurance is established by the architecture. Basis: REQ-03, REQ-04, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define storage budgets and recovery objectives; demonstrate consistent restoration. Verification plan: Perform bounded capacity and restore exercises using disposable data. Owner and disposition: unassigned; review pending.

Activity cannot be reliably reconstructed

Repudiation, Open, Medium Priority

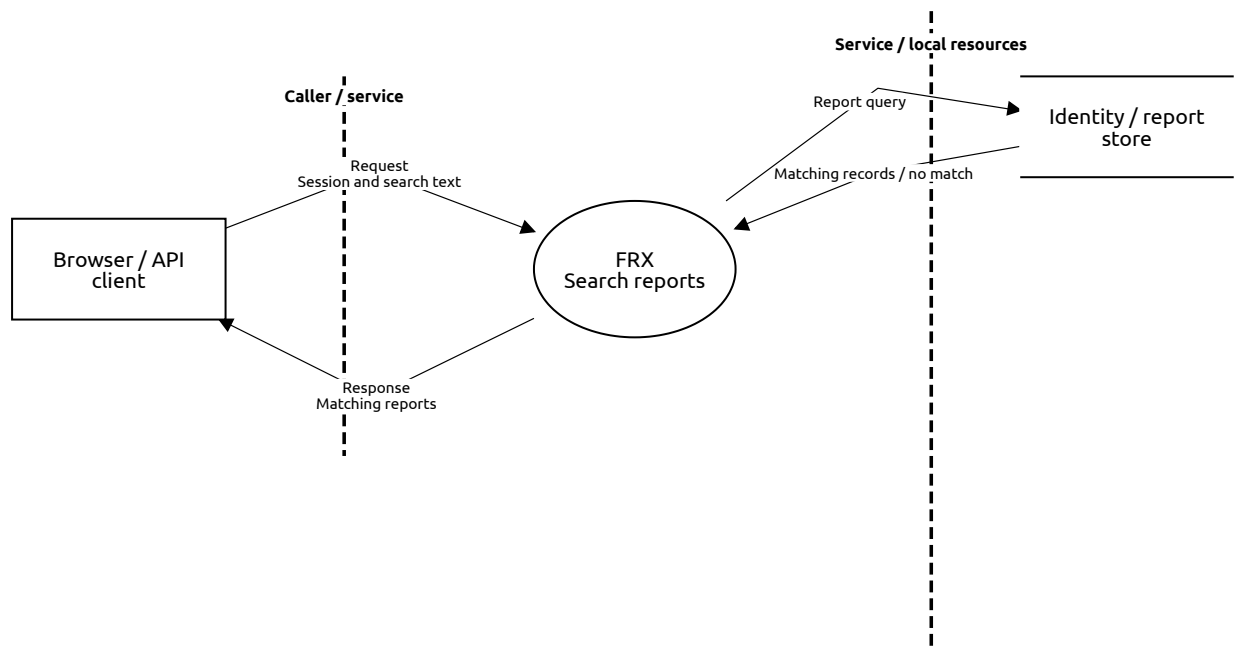
Description:

Preconditions: A caller disputes an action, or an attacker can omit, forge or alter event records. Assets: Event attribution and integrity. Consequences: Reviewers could be unable to establish who accessed data or changed intake. Architecture constraints: Selected actions append local events; completeness, timestamps, escaping and tamper protection are unverified. Basis: REQ-05, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define required events; record actor, action, outcome, time and correlation safely, and protect retention. Verification plan: Reconcile successful and rejected requests with events; test hostile field values and log access controls. Owner and disposition: unassigned; review pending.

07 FRX GET /search



Request Session and search text (Data Flow)

Description:

Caller inputs cross the service boundary. Authority must be established independently of supplied identifiers. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: Applicable: attached scenario. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Sensitive request or response observed in transit

Information disclosure, Open, Medium Priority

Description:

Preconditions: An attacker can observe local traffic or impersonate the service endpoint. Assets: Credentials, session cookies and report data. Consequences: Observed data could disclose reports or permit account/session misuse. Architecture constraints: Loopback limits reach; authenticated encrypted transport is not established by this planning baseline. Basis: REQ-02, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define transport confidentiality and endpoint-authentication controls and verify client trust. Verification plan: Inspect permitted protocols and certificate validation using a controlled local client. Owner and disposition: unassigned; review pending.

Response Matching reports (Data Flow)

Description:

Return the endpoint result or error. An acknowledgement does not imply an out-of-scope workflow. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: Applicable: attached scenario. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Sensitive request or response observed in transit

Information disclosure, Open, Medium Priority

Description:

Preconditions: An attacker can observe local traffic or impersonate the service endpoint. Assets: Credentials, session cookies and report data. Consequences: Observed data could disclose reports or permit account/session misuse. Architecture constraints: Loopback limits reach; authenticated encrypted transport is not established by this planning baseline. Basis: REQ-02, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define transport confidentiality and endpoint-authentication controls and verify client trust. Verification plan: Inspect permitted protocols and certificate validation using a controlled local client. Owner and disposition: unassigned; review pending.

Report query (Data Flow)

Description:

Local database read; authorization and query safety are separate decisions. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Stored content altered outside the request policy

Tampering, Open, Medium Priority

Description:

Preconditions: An attacker has write access to this local resource. Assets: Identity / report store. Consequences: Changes could corrupt reports, intake, browser assets or audit evidence, depending on the resource. Architecture constraints: Local storage is part of the architecture; separate permissions or protection zones are not assumed. Basis: REQ-02, REQ-03, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Restrict writes to authorized functions, protect published assets and verify integrity/recovery controls. Verification plan: Review access rights and test unauthorized modification and recovery. Owner and disposition: unassigned; review pending.

Matching records / no match (Data Flow)

Description:

Record contents enter request-processing memory. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: Applicable: attached scenario. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Stored data read by an unintended principal

Information disclosure, Open, Medium Priority

Description:

Preconditions: An attacker can read local files or an unprotected copy. Assets: Identity / report store. Consequences: Sensitive records or credentials could be exposed. Architecture constraints: Synthetic data is used locally; permissions, encryption and backup protection require confirmation. Basis: REQ-02, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Apply least-privilege access and appropriate encryption/backup controls. Verification plan: Review permitted readers, copies and key custody. Owner and disposition: unassigned; review pending.

Browser / API client (External Actor)

Description:

Untrusted local caller. Partner, analyst and administrator roles matter where authenticated authority is required. Public operations accept anonymous callers. STRIDE applicability: Spoofing: Applicable: attached scenario. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Forged or replayed session identity

Spoofing, Open, High Priority

Description:

Preconditions: An attacker obtains a session cookie or gains knowledge of its signing key. Assets: User identity and role authority. Consequences: The attacker could act as another user, including a privileged user. Architecture constraints: Credential login and signed cookies are part of the architecture; key custody, expiry and revocation are unverified. Basis: REQ-01, REQ-02, ARC-02, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Protect and rotate signing keys, constrain cookie use and lifetime, and define revocation and identity revalidation. Verification plan: Attempt altered and replayed cookies, including after logout and account disablement. Owner and disposition: unassigned; review pending.

FRX Search reports (Process)

Description:

Search report titles and summaries. Result disclosure must follow the report-access policy. No dedicated application audit side effect is included here. Basis: REQ-01, REQ-05, ARC-02 STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: Applicable: attached scenario. Information disclosure: Applicable: attached scenario. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Repeated requests exhaust service capacity

Denial of service, Open, Medium Priority

Description:

Preconditions: A caller can repeatedly reach this interface; normal protected operations require a session. Assets: Local service availability. Consequences: Request work could delay report review, especially when file, database or provider work shares capacity. Architecture constraints: Loopback exposure and bounded portal request bodies limit some inputs; rate limits and capacity guarantees are unverified. Basis: REQ-04, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define request/concurrency budgets and ensure advisory-provider failure does not prevent report review. Verification plan: Use an agreed bounded load profile and provider-failure scenarios. Owner and disposition: unassigned; review pending.

Search input changes query meaning

Tampering, Open, High Priority

Description:

Preconditions: A signed-in caller supplies search text. Assets: Query integrity and readable records. Consequences: If input becomes query syntax, the result could include unintended records or fields. Architecture constraints: Session authentication limits normal callers; safe query construction is not assumed. Basis: REQ-01, REQ-02, ARC-02. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Separate query structure from input and constrain result size and fields. Verification plan: Exercise query-control characters, empty searches and broad wildcard requests. Owner and disposition: unassigned; review pending.

Search exposes reports outside the caller policy

Description:

Preconditions: A signed-in user issues a broad or targeted search. Assets: Report contents. Consequences: The result set could bypass access checks present on individual report reads. Architecture constraints: Record access requirements apply to search independently of the detail interface. Basis: REQ-01, ARC-02. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Filter all returned records using the intended ownership/assignment/role rule. Verification plan: Compare search results with the complete permitted-report set for every role. Owner and disposition: unassigned; review pending.

Activity cannot be reliably reconstructed

Repudiation, Open, Medium Priority

Description:

Preconditions: A caller disputes an action, or an attacker can omit, forge or alter event records. Assets: Event attribution and integrity. Consequences: Reviewers could be unable to establish who accessed data or changed intake. Architecture constraints: Selected actions append local events; completeness, timestamps, escaping and tamper protection are unverified. Basis: REQ-05, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define required events; record actor, action, outcome, time and correlation safely, and protect retention. Verification plan: Reconcile successful and rejected requests with events; test hostile field values and log access controls. Owner and disposition: unassigned; review pending.

Identity / report store (Data Store)

Description:

Local resource accessed directly by FRX; no independently enforced storage zone is asserted. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: Applicable: attached scenario. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Stored content altered outside the request policy

Tampering, Open, Medium Priority

Description:

Preconditions: An attacker has write access to this local resource. Assets: Identity / report store. Consequences: Changes could corrupt reports, intake, browser assets or audit evidence, depending on the resource. Architecture constraints: Local storage is part of the architecture; separate permissions or protection zones are not assumed. Basis: REQ-02, REQ-03, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Restrict writes to authorized functions, protect published assets and verify integrity/recovery controls. Verification plan: Review access rights and test unauthorized modification and recovery. Owner and disposition: unassigned; review pending.

Stored data read by an unintended principal

Information disclosure, Open, Medium Priority

Description:

Preconditions: An attacker can read local files or an unprotected copy. Assets: Identity / report store. Consequences: Sensitive records or credentials could be exposed. Architecture constraints: Synthetic data is used locally; permissions, encryption and backup protection require confirmation. Basis: REQ-02, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Apply least-privilege access and appropriate encryption/backup controls. Verification plan: Review permitted readers, copies and key custody. Owner and disposition: unassigned; review pending.

Storage loss or unavailability interrupts work

Denial of service, Open, Medium Priority

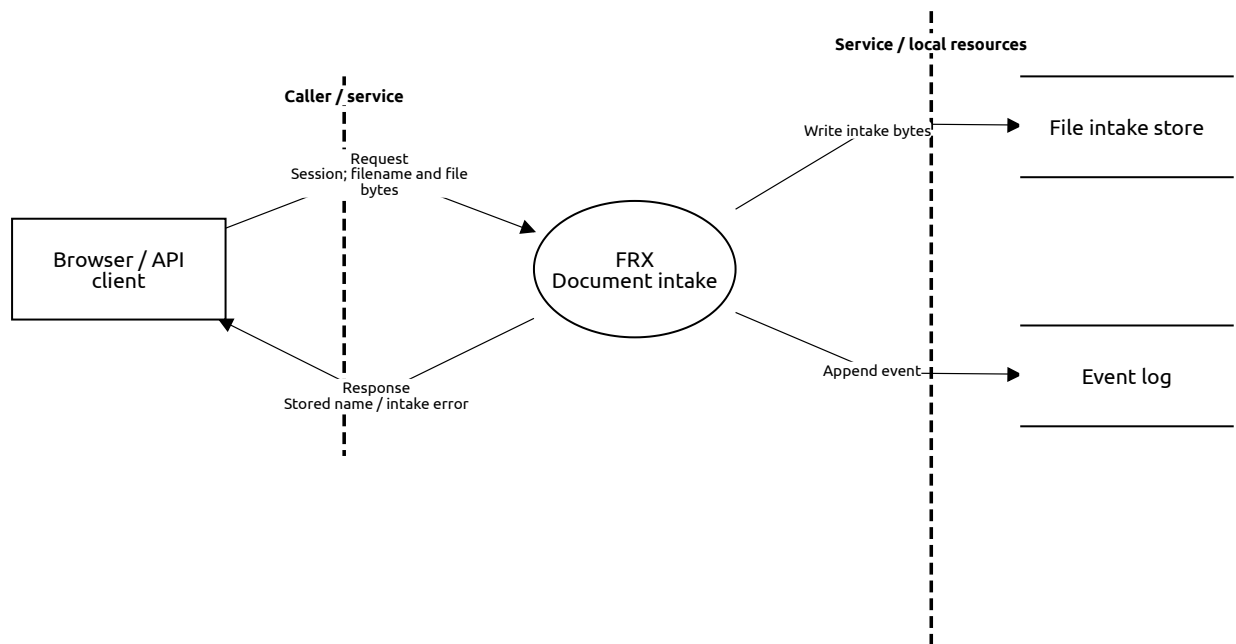
Description:

Preconditions: Storage fills, fails, is locked or is removed. Assets: Identity / report store. Consequences: Reports, intake or event records could become unavailable or be lost. Architecture constraints: No recovery assurance is established by the architecture. Basis: REQ-03, REQ-04, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define storage budgets and recovery objectives; demonstrate consistent restoration. Verification plan: Perform bounded capacity and restore exercises using disposable data. Owner and disposition: unassigned; review pending.

08 FRX POST /documents



Request Session; filename and file bytes (Data Flow)

Description:

Caller inputs cross the service boundary. Authority must be established independently of supplied identifiers. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: Applicable: attached scenario. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Sensitive request or response observed in transit

Information disclosure, Open, Medium Priority

Description:

Preconditions: An attacker can observe local traffic or impersonate the service endpoint. Assets: Credentials, session cookies and report data. Consequences: Observed data could disclose reports or permit account/session misuse. Architecture constraints: Loopback limits reach; authenticated encrypted transport is not established by this planning baseline. Basis: REQ-02, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define transport confidentiality and endpoint-authentication controls and verify client trust. Verification plan: Inspect permitted protocols and certificate validation using a controlled local client. Owner and disposition: unassigned; review pending.

Response Stored name / intake error (Data Flow)

Description:

Return the endpoint result or error. An acknowledgement does not imply an out-of-scope workflow. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: Applicable: attached scenario. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Sensitive request or response observed in transit

Information disclosure, Open, Medium Priority

Description:

Preconditions: An attacker can observe local traffic or impersonate the service endpoint. Assets: Credentials, session cookies and report data. Consequences: Observed data could disclose reports or permit account/session misuse. Architecture constraints: Loopback limits reach; authenticated encrypted transport is not established by this planning baseline. Basis: REQ-02, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define transport confidentiality and endpoint-authentication controls and verify client trust. Verification plan: Inspect permitted protocols and certificate validation using a controlled local client. Owner and disposition: unassigned; review pending.

Write intake bytes (Data Flow)

Description:

Persistent side effect; write failures can affect request completion. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Stored content altered outside the request policy

Tampering, Open, Medium Priority

Description:

Preconditions: An attacker has write access to this local resource. Assets: File intake store. Consequences: Changes could corrupt reports, intake, browser assets or audit evidence, depending on the resource. Architecture constraints: Local storage is part of the architecture; separate permissions or protection zones are not assumed. Basis: REQ-02, REQ-03, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Restrict writes to authorized functions, protect published assets and verify integrity/recovery controls. Verification plan: Review access rights and test unauthorized modification and recovery. Owner and disposition: unassigned; review pending.

Append event (Data Flow)

Description:

Persistent side effect; write failures can affect request completion. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Stored content altered outside the request policy

Tampering, Open, Medium Priority

Description:

Preconditions: An attacker has write access to this local resource. Assets: Event log. Consequences: Changes could corrupt reports, intake, browser assets or audit evidence, depending on the resource. Architecture constraints: Local storage is part of the architecture; separate permissions or protection zones are not assumed. Basis: REQ-02, REQ-03, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Restrict writes to authorized functions, protect published assets and verify integrity/recovery controls. Verification plan: Review access rights and test unauthorized modification and recovery. Owner and disposition: unassigned; review pending.

Browser / API client (External Actor)

Description:

Untrusted local caller. Partner, analyst and administrator roles matter where authenticated authority is required. Public operations accept anonymous callers. STRIDE applicability: Spoofing: Applicable: attached scenario. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Forged or replayed session identity

Spoofing, Open, High Priority

Description:

Preconditions: An attacker obtains a session cookie or gains knowledge of its signing key. Assets: User identity and role authority. Consequences: The attacker could act as another user, including a privileged user. Architecture constraints: Credential login and signed cookies are part of the architecture; key custody, expiry and revocation are unverified. Basis: REQ-01, REQ-02, ARC-02, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Protect and rotate signing keys, constrain cookie use and lifetime, and define revocation and identity revalidation. Verification plan: Attempt altered and replayed cookies, including after logout and account disablement. Owner and disposition: unassigned; review pending.

FRX Document intake (Process)

Description:

Store a standalone submitted file and append an intake event. No report association, retrieval or ownership record is in scope. Basis: REQ-03, ARC-04 STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Repeated requests exhaust service capacity

Denial of service, Open, Medium Priority

Description:

Preconditions: A caller can repeatedly reach this interface; normal protected operations require a session. Assets: Local service availability. Consequences: Request work could delay report review, especially when file, database or provider work shares capacity. Architecture constraints: Loopback exposure and bounded portal request bodies limit some inputs; rate limits and capacity guarantees are unverified. Basis: REQ-04, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define request/concurrency budgets and ensure advisory-provider failure does not prevent report review. Verification plan: Use an agreed bounded load profile and provider-failure scenarios. Owner and disposition: unassigned; review pending.

Submitted filename replaces earlier intake

Tampering, Open, High Priority

Description:

Preconditions: A signed-in caller submits a filename that collides with existing intake. Assets: Acknowledged file integrity. Consequences: An earlier document could be overwritten without a deliberate replacement workflow. Architecture constraints: Writes are confined to disposable intake storage; containment does not prevent filename collisions. Basis: REQ-03, ARC-04. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Assign unique storage names, define collision behavior and preserve acknowledged content. Verification plan: Submit duplicate names with distinct bytes and verify original content is preserved. Owner and disposition: unassigned; review pending.

Repeated intake consumes shared disk capacity

Denial of service, Open, Medium Priority

Description:

Preconditions: A signed-in caller submits many individually acceptable files. Assets: Intake and portal availability. Consequences: Full storage could disrupt intake, database work or logging and threaten preservation. Architecture constraints: A per-request size bound is part of the baseline; aggregate quota and recovery are unverified. Basis: REQ-03, REQ-04, ARC-04. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Set aggregate quotas, retention, capacity alerts and verified restore procedures. Verification plan: Use bounded quota, disk-full and restore exercises on disposable storage. Owner and disposition: unassigned; review pending.

Browser submits an unintended operation

Tampering, Open, Medium Priority

Description:

Preconditions: A hostile page induces a browser request and relevant cookies or login fields are accepted. Assets: User intent and request integrity. Consequences: An unwanted login, logout, intake or inspection request could run in the user context. Architecture constraints: Cookie-associated workflows are in scope; origin validation and anti-forgery protections are unverified. Basis: REQ-02, ARC-02. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define origin and anti-forgery controls for browser operations, including session transitions. Verification plan: Exercise cross-site submissions in a controlled browser and verify intended user actions still work. Owner and disposition: unassigned; review pending.

File intake store (Data Store)

Description:

Local resource accessed directly by FRX; no independently enforced storage zone is asserted. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: Applicable: attached scenario. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Stored content altered outside the request policy

Tampering, Open, Medium Priority

Description:

Preconditions: An attacker has write access to this local resource. Assets: File intake store. Consequences: Changes could corrupt reports, intake, browser assets or audit evidence, depending on the resource. Architecture constraints: Local storage is part of the architecture; separate permissions or protection zones are not assumed. Basis: REQ-02, REQ-03, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Restrict writes to authorized functions, protect published assets and verify integrity/recovery controls. Verification plan: Review access rights and test unauthorized modification and recovery. Owner and disposition: unassigned; review pending.

Stored data read by an unintended principal

Information disclosure, Open, Medium Priority

Description:

Preconditions: An attacker can read local files or an unprotected copy. Assets: File intake store. Consequences: Sensitive records or credentials could be exposed. Architecture constraints: Synthetic data is used locally; permissions, encryption and backup protection require confirmation. Basis: REQ-02, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Apply least-privilege access and appropriate encryption/backup controls. Verification plan: Review permitted readers, copies and key custody. Owner and disposition: unassigned; review pending.

Storage loss or unavailability interrupts work

Denial of service, Open, Medium Priority

Description:

Preconditions: Storage fills, fails, is locked or is removed. Assets: File intake store. Consequences: Reports, intake or event records could become unavailable or be lost. Architecture constraints: No recovery assurance is established by the architecture. Basis: REQ-03, REQ-04, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define storage budgets and recovery objectives; demonstrate consistent restoration. Verification plan: Perform bounded capacity and restore exercises using disposable data. Owner and disposition: unassigned; review pending.

Event log (Data Store)

Description:

Local resource accessed directly by FRX; no independently enforced storage zone is asserted. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: Applicable: attached scenario. Information disclosure: Applicable: attached scenario. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Stored content altered outside the request policy

Tampering, Open, Medium Priority

Description:

Preconditions: An attacker has write access to this local resource. Assets: Event log. Consequences: Changes could corrupt reports, intake, browser assets or audit evidence, depending on the resource. Architecture constraints: Local storage is part of the architecture; separate permissions or protection zones are not assumed. Basis: REQ-02, REQ-03, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Restrict writes to authorized functions, protect published assets and verify integrity/recovery controls. Verification plan: Review access rights and test unauthorized modification and recovery. Owner and disposition: unassigned; review pending.

Stored data read by an unintended principal

Information disclosure, Open, Medium Priority

Description:

Preconditions: An attacker can read local files or an unprotected copy. Assets: Event log. Consequences: Sensitive records or credentials could be exposed. Architecture constraints: Synthetic data is used locally; permissions, encryption and backup protection require confirmation. Basis: REQ-02, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Apply least-privilege access and appropriate encryption/backup controls. Verification plan: Review permitted readers, copies and key custody. Owner and disposition: unassigned; review pending.

Storage loss or unavailability interrupts work

Denial of service, Open, Medium Priority

Description:

Preconditions: Storage fills, fails, is locked or is removed. Assets: Event log. Consequences: Reports, intake or event records could become unavailable or be lost. Architecture constraints: No recovery assurance is established by the architecture. Basis: REQ-03, REQ-04, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define storage budgets and recovery objectives; demonstrate consistent restoration. Verification plan: Perform bounded capacity and restore exercises using disposable data. Owner and disposition: unassigned; review pending.

Activity cannot be reliably reconstructed

Repudiation, Open, Medium Priority

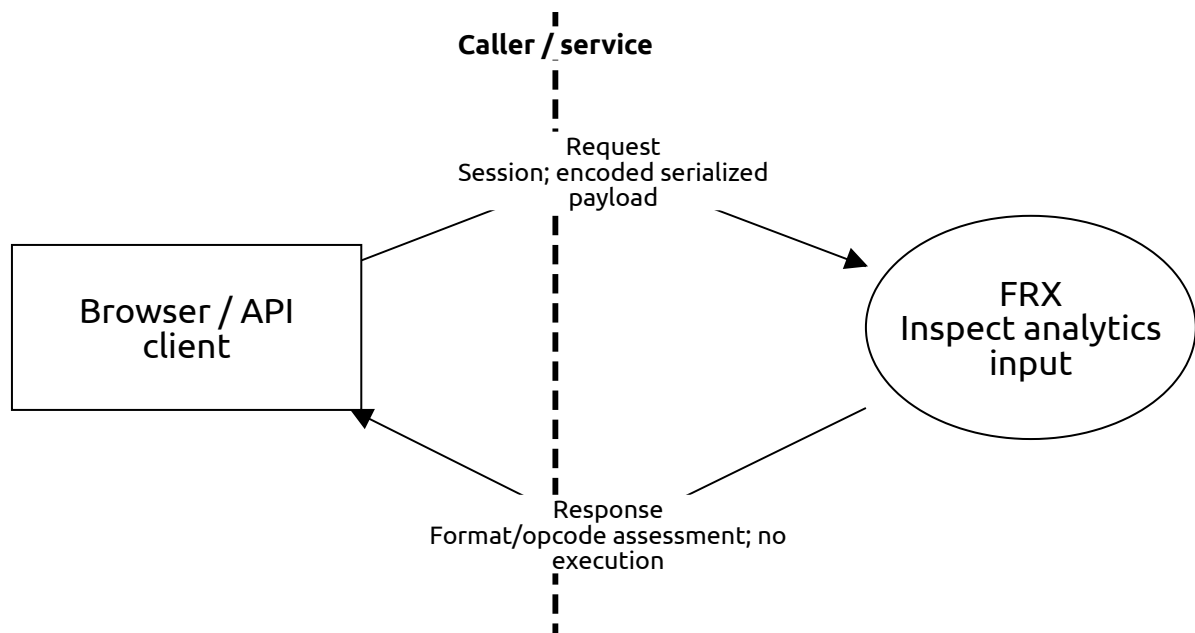
Description:

Preconditions: A caller disputes an action, or an attacker can omit, forge or alter event records. Assets: Event attribution and integrity. Consequences: Reviewers could be unable to establish who accessed data or changed intake. Architecture constraints: Selected actions append local events; completeness, timestamps, escaping and tamper protection are unverified. Basis: REQ-05, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define required events; record actor, action, outcome, time and correlation safely, and protect retention. Verification plan: Reconcile successful and rejected requests with events; test hostile field values and log access controls. Owner and disposition: unassigned; review pending.

09 FRX POST /analytics/import



Request Session; encoded serialized payload (Data Flow)

Description:

Caller inputs cross the service boundary. Authority must be established independently of supplied identifiers. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: Applicable: attached scenario. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Sensitive request or response observed in transit

Information disclosure, Open, Medium Priority

Description:

Preconditions: An attacker can observe local traffic or impersonate the service endpoint. Assets: Credentials, session cookies and report data. Consequences: Observed data could disclose reports or permit account/session misuse. Architecture constraints: Loopback limits reach; authenticated encrypted transport is not established by this planning baseline. Basis: REQ-02, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define transport confidentiality and endpoint-authentication controls and verify client trust. Verification plan: Inspect permitted protocols and certificate validation using a controlled local client. Owner and disposition: unassigned; review pending.

Response Format/opcode assessment; no execution (Data Flow)

Description:

Return the endpoint result or error. An acknowledgement does not imply an out-of-scope workflow. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: Applicable: attached scenario. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Sensitive request or response observed in transit

Information disclosure, Open, Medium Priority

Description:

Preconditions: An attacker can observe local traffic or impersonate the service endpoint. Assets: Credentials, session cookies and report data. Consequences: Observed data could disclose reports or permit account/session misuse. Architecture constraints: Loopback limits reach; authenticated encrypted transport is not established by this planning baseline. Basis: REQ-02, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define transport confidentiality and endpoint-authentication controls and verify client trust. Verification plan: Inspect permitted protocols and certificate validation using a controlled local client. Owner and disposition: unassigned; review pending.

Browser / API client (External Actor)

Description:

Untrusted local caller. Partner, analyst and administrator roles matter where authenticated authority is required. Public operations accept anonymous callers. STRIDE applicability: Spoofing: Applicable: attached scenario. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Forged or replayed session identity

Spoofing, Open, High Priority

Description:

Preconditions: An attacker obtains a session cookie or gains knowledge of its signing key. Assets: User identity and role authority. Consequences: The attacker could act as another user, including a privileged user. Architecture constraints: Credential login and signed cookies are part of the architecture; key custody, expiry and revocation are unverified. Basis: REQ-01, REQ-02, ARC-02, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Protect and rotate signing keys, constrain cookie use and lifetime, and define revocation and identity revalidation. Verification plan: Attempt altered and replayed cookies, including after logout and account disablement. Owner and disposition: unassigned; review pending.

FRX Inspect analytics input (Process)

Description:

Inspect the submitted serialized representation without executing it. Return an assessment only; no database write, report lookup or report-authority decision. Basis: ARC-05 STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: Applicable: attached scenario. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Repeated requests exhaust service capacity

Denial of service, Open, Medium Priority

Description:

Preconditions: A caller can repeatedly reach this interface; normal protected operations require a session. Assets: Local service availability. Consequences: Request work could delay report review, especially when file, database or provider work shares capacity. Architecture constraints: Loopback exposure and bounded portal request bodies limit some inputs; rate limits and capacity guarantees are unverified. Basis: REQ-04, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define request/concurrency budgets and ensure advisory-provider failure does not prevent report review. Verification plan: Use an agreed bounded load profile and provider-failure scenarios. Owner and disposition: unassigned; review pending.

Complex serialized input consumes parser resources

Denial of service, Open, Medium Priority

Description:

Preconditions: A signed-in caller supplies malformed or costly serialized input. Assets: Parser and portal availability. Consequences: Parsing work or uncontrolled errors could degrade request handling. Architecture constraints: Request size is bounded and inspection is nonexecuting. Code execution is not a modeled behavior. Basis: REQ-04, ARC-05. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Keep inspection nonexecuting, bound parser work and handle malformed representations safely. Verification plan: Test malformed and high-complexity bounded payloads; verify no payload execution or persistence. Owner and disposition: unassigned; review pending.

Inspection result mistaken for trusted analytics

Tampering, Open, Medium Priority

Description:

Preconditions: A caller or downstream user treats an assessment as accepted report analytics. Assets: Interpretation of analytics data. Consequences: Unverified content could influence a decision despite no report relationship or persistence. Architecture constraints: This interface returns inspection results, not an authoritative report update. Basis: ARC-05. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Label assessment results clearly and require provenance, semantic validation and report authority before any future downstream use. Verification plan: Verify UI/API descriptions and downstream consumers do not treat inspection as approval or persistence. Owner and disposition: unassigned; review pending.

Activity cannot be reliably reconstructed

Repudiation, Open, Medium Priority

Description:

Preconditions: A caller disputes an action, or an attacker can omit, forge or alter event records. Assets: Event attribution and integrity. Consequences: Reviewers could be unable to establish who accessed data or changed intake. Architecture constraints: Selected actions append local events; completeness, timestamps, escaping and tamper protection are unverified. Basis: REQ-05, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define required events; record actor, action, outcome, time and correlation safely, and protect retention. Verification plan: Reconcile successful and rejected requests with events; test hostile field values and log access controls. Owner and disposition: unassigned; review pending.

Browser submits an unintended operation

Tampering, Open, Medium Priority

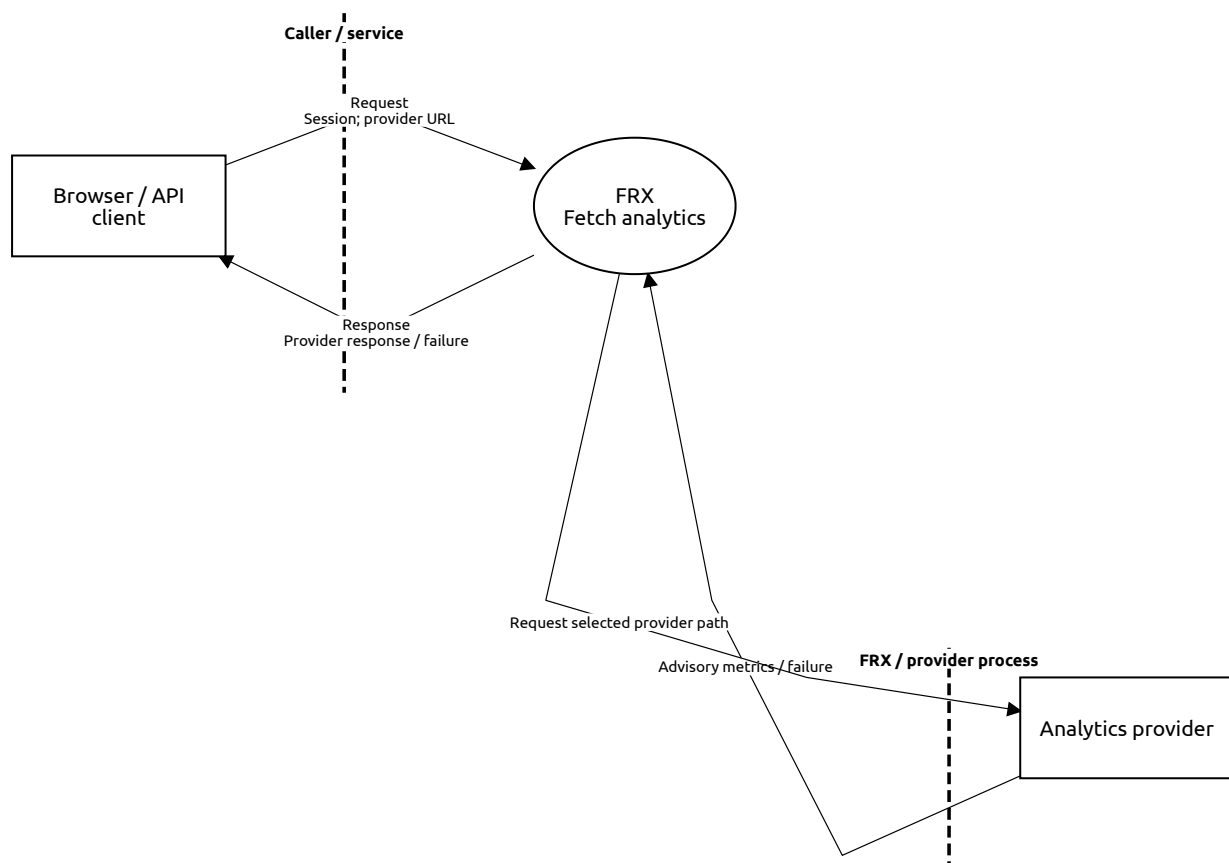
Description:

Preconditions: A hostile page induces a browser request and relevant cookies or login fields are accepted. Assets: User intent and request integrity. Consequences: An unwanted login, logout, intake or inspection request could run in the user context. Architecture constraints: Cookie-associated workflows are in scope; origin validation and anti-forgery protections are unverified. Basis: REQ-02, ARC-02. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define origin and anti-forgery controls for browser operations, including session transitions. Verification plan: Exercise cross-site submissions in a controlled browser and verify intended user actions still work. Owner and disposition: unassigned; review pending.

10 FRX GET /analytics/fetch



Request Session; provider URL (Data Flow)

Description:

Caller inputs cross the service boundary. Authority must be established independently of supplied identifiers. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: Applicable: attached scenario. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Sensitive request or response observed in transit

Information disclosure, Open, Medium Priority

Description:

Preconditions: An attacker can observe local traffic or impersonate the service endpoint. Assets: Credentials, session cookies and report data. Consequences: Observed data could disclose reports or permit account/session misuse. Architecture constraints: Loopback limits reach; authenticated encrypted transport is not established by this planning baseline. Basis: REQ-02, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define transport confidentiality and endpoint-authentication controls and verify client trust. Verification plan: Inspect permitted protocols and certificate validation using a controlled local client. Owner and disposition: unassigned; review pending.

Response Provider response / failure (Data Flow)

Description:

Return the endpoint result or error. An acknowledgement does not imply an out-of-scope workflow. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: Applicable: attached scenario. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Sensitive request or response observed in transit

Information disclosure, Open, Medium Priority

Description:

Preconditions: An attacker can observe local traffic or impersonate the service endpoint. Assets: Credentials, session cookies and report data. Consequences: Observed data could disclose reports or permit account/session misuse. Architecture constraints: Loopback limits reach; authenticated encrypted transport is not established by this planning baseline. Basis: REQ-02, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define transport confidentiality and endpoint-authentication controls and verify client trust. Verification plan: Inspect permitted protocols and certificate validation using a controlled local client. Owner and disposition: unassigned; review pending.

Request selected provider path (Data Flow)

Description:

Configured-origin restriction; bounded wait. No report-store query is performed by this exchange. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: Applicable: attached scenario.

Provider path selection exceeds intended report authority

Elevation of privilege, Open, High Priority

Description:

Preconditions: A signed-in caller selects another report metric or another path on the permitted origin. Assets: Authorized use of analytics. Consequences: The portal could act on requests outside the caller intended report scope. Architecture constraints: Outbound access is restricted to the configured loopback provider origin; unrestricted external access is not assumed. Basis: REQ-01, ARC-03. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define allowed operations and report authority; construct approved provider paths after authorization. Verification plan: Test alternate permitted-origin paths and unrelated report identifiers; verify other origins are rejected. Owner and disposition: unassigned; review pending.

Advisory metrics / failure (Data Flow)

Description:

Bounded response; no analytics persistence. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Provider response misleads advisory decisions

Tampering, Open, Medium Priority

Description:

Preconditions: The provider or its local communication path supplies altered or unrelated data. Assets: Metric integrity and report association. Consequences: Users could prioritize work based on false scores or a metric for the wrong report. Architecture constraints: Configured-origin restriction, response-size bound and timeout constrain the exchange. Provider data remains untrusted; there is no report-store connection. Basis: REQ-04, ARC-03, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Validate response identity and semantics; establish provider identity and preserve review without metrics. Verification plan: Test mismatched identifiers, malformed data, altered scores and timeout behavior. Owner and disposition: unassigned; review pending.

Browser / API client (External Actor)

Description:

Untrusted local caller. Partner, analyst and administrator roles matter where authenticated authority is required. Public operations accept anonymous callers. STRIDE applicability: Spoofing: Applicable: attached scenario. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Forged or replayed session identity

Spoofing, Open, High Priority

Description:

Preconditions: An attacker obtains a session cookie or gains knowledge of its signing key. Assets: User identity and role authority. Consequences: The attacker could act as another user, including a privileged user. Architecture constraints: Credential login and signed cookies are part of the architecture; key custody, expiry and revocation are unverified. Basis: REQ-01, REQ-02, ARC-02, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Protect and rotate signing keys, constrain cookie use and lifetime, and define revocation and identity revalidation. Verification plan: Attempt altered and replayed cookies, including after logout and account disablement. Owner and disposition: unassigned; review pending.

FRX Fetch analytics (Process)

Description:

Fetch a caller-selected path on the configured local provider origin and return its response. No report database lookup, persistence or dedicated application audit event is included. Basis: REQ-04, ARC-03 STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: Applicable: attached scenario. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: Applicable: attached scenario. Elevation of privilege: Applicable: attached scenario.

Repeated requests exhaust service capacity

Denial of service, Open, Medium Priority

Description:

Preconditions: A caller can repeatedly reach this interface; normal protected operations require a session. Assets: Local service availability. Consequences: Request work could delay report review, especially when file, database or provider work shares capacity. Architecture constraints: Loopback exposure and bounded portal request bodies limit some inputs; rate limits and capacity guarantees are unverified. Basis: REQ-04, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define request/concurrency budgets and ensure advisory-provider failure does not prevent report review. Verification plan: Use an agreed bounded load profile and provider-failure scenarios. Owner and disposition: unassigned; review pending.

Provider path selection exceeds intended report authority

Elevation of privilege, Open, High Priority

Description:

Preconditions: A signed-in caller selects another report metric or another path on the permitted origin. Assets: Authorized use of analytics. Consequences: The portal could act on requests outside the caller intended report scope. Architecture constraints: Outbound access is restricted to the configured loopback provider origin; unrestricted external access is not assumed. Basis: REQ-01, ARC-03. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define allowed operations and report authority; construct approved provider paths after authorization. Verification plan: Test alternate permitted-origin paths and unrelated report identifiers; verify other origins are rejected. Owner and disposition: unassigned; review pending.

Activity cannot be reliably reconstructed

Repudiation, Open, Medium Priority

Description:

Preconditions: A caller disputes an action, or an attacker can omit, forge or alter event records. Assets: Event attribution and integrity. Consequences: Reviewers could be unable to establish who accessed data or changed intake. Architecture constraints: Selected actions append local events; completeness, timestamps, escaping and tamper protection are unverified. Basis: REQ-05, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define required events; record actor, action, outcome, time and correlation safely, and protect retention. Verification plan: Reconcile successful and rejected requests with events; test hostile field values and log access controls. Owner and disposition: unassigned; review pending.

Analytics provider (External Actor)

Description:

Separate local process owns response content; synthetic advisory metrics do not establish report authority. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Provider response misleads advisory decisions

Tampering, Open, Medium Priority

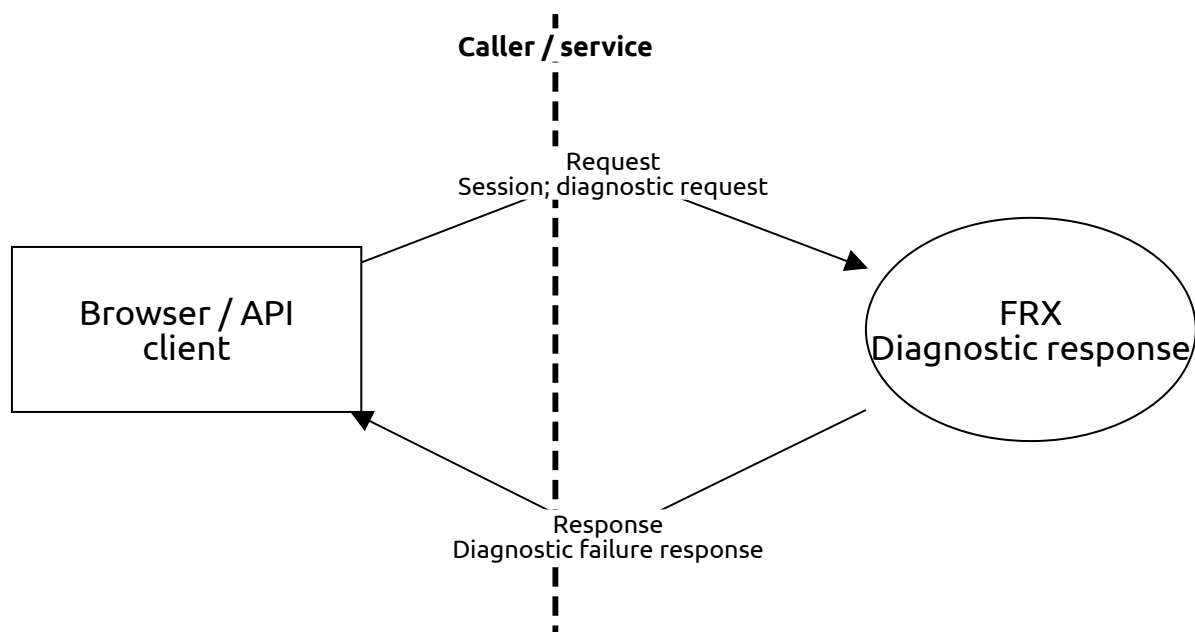
Description:

Preconditions: The provider or its local communication path supplies altered or unrelated data. Assets: Metric integrity and report association. Consequences: Users could prioritize work based on false scores or a metric for the wrong report. Architecture constraints: Configured-origin restriction, response-size bound and timeout constrain the exchange. Provider data remains untrusted; there is no report-store connection. Basis: REQ-04, ARC-03, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Validate response identity and semantics; establish provider identity and preserve review without metrics. Verification plan: Test mismatched identifiers, malformed data, altered scores and timeout behavior. Owner and disposition: unassigned; review pending.

11 FRX GET /errors/demo



Request Session; diagnostic request (Data Flow)

Description:

Caller inputs cross the service boundary. Authority must be established independently of supplied identifiers. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: Applicable: attached scenario. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Sensitive request or response observed in transit

Information disclosure, Open, Medium Priority

Description:

Preconditions: An attacker can observe local traffic or impersonate the service endpoint. Assets: Credentials, session cookies and report data. Consequences: Observed data could disclose reports or permit account/session misuse. Architecture constraints: Loopback limits reach; authenticated encrypted transport is not established by this planning baseline. Basis: REQ-02, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define transport confidentiality and endpoint-authentication controls and verify client trust. Verification plan: Inspect permitted protocols and certificate validation using a controlled local client. Owner and disposition: unassigned; review pending.

Response Diagnostic failure response (Data Flow)

Description:

Return the endpoint result or error. An acknowledgement does not imply an out-of-scope workflow. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: Applicable: attached scenario. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Sensitive request or response observed in transit

Information disclosure, Open, Medium Priority

Description:

Preconditions: An attacker can observe local traffic or impersonate the service endpoint. Assets: Credentials, session cookies and report data. Consequences: Observed data could disclose reports or permit account/session misuse. Architecture constraints: Loopback limits reach; authenticated encrypted transport is not established by this planning baseline. Basis: REQ-02, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define transport confidentiality and endpoint-authentication controls and verify client trust. Verification plan: Inspect permitted protocols and certificate validation using a controlled local client. Owner and disposition: unassigned; review pending.

Browser / API client (External Actor)

Description:

Untrusted local caller. Partner, analyst and administrator roles matter where authenticated authority is required. Public operations accept anonymous callers. STRIDE applicability: Spoofing: Applicable: attached scenario. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Forged or replayed session identity

Spoofing, Open, High Priority

Description:

Preconditions: An attacker obtains a session cookie or gains knowledge of its signing key. Assets: User identity and role authority. Consequences: The attacker could act as another user, including a privileged user. Architecture constraints: Credential login and signed cookies are part of the architecture; key custody, expiry and revocation are unverified. Basis: REQ-01, REQ-02, ARC-02, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Protect and rotate signing keys, constrain cookie use and lifetime, and define revocation and identity revalidation. Verification plan: Attempt altered and replayed cookies, including after logout and account disablement. Owner and disposition: unassigned; review pending.

FRX Diagnostic response (Process)

Description:

Return a deliberate diagnostic failure. No additional application event-log side effect is included for this interface. Basis: REQ-02, ARC-06 STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: Applicable: attached scenario. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Repeated requests exhaust service capacity

Denial of service, Open, Medium Priority

Description:

Preconditions: A caller can repeatedly reach this interface; normal protected operations require a session. Assets: Local service availability. Consequences: Request work could delay report review, especially when file, database or provider work shares capacity. Architecture constraints: Loopback exposure and bounded portal request bodies limit some inputs; rate limits and capacity guarantees are unverified. Basis: REQ-04, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define request/concurrency budgets and ensure advisory-provider failure does not prevent report review. Verification plan: Use an agreed bounded load profile and provider-failure scenarios. Owner and disposition: unassigned; review pending.

Diagnostic content exposes sensitive internals

Information disclosure, Open, High Priority

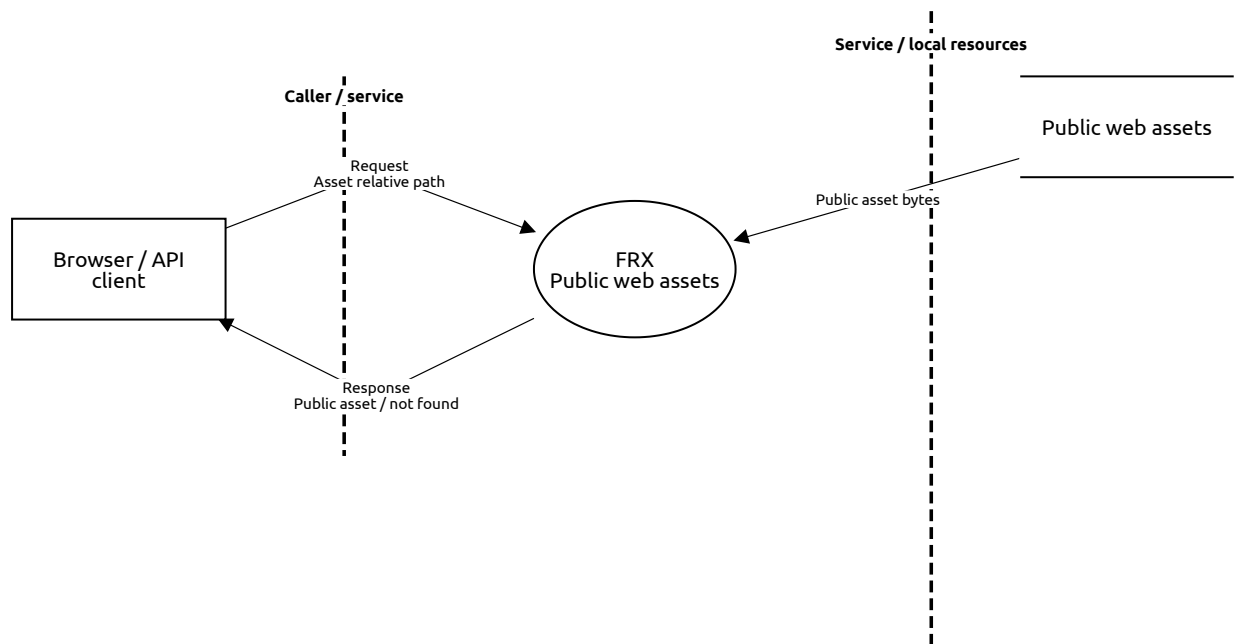
Description:

Preconditions: A signed-in caller invokes diagnostics or triggers an unexpected error. Assets: Keys, internal paths and operational details. Consequences: Overly detailed responses could disclose secrets or information useful for further attacks. Architecture constraints: The diagnostic interface requires a session; that alone does not authorize disclosure of internals. Basis: REQ-02, ARC-06. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Use minimal public errors, restrict diagnostics and keep sensitive details in appropriately protected operator records. Verification plan: Inspect deliberate and unexpected errors for keys, credentials, internal paths and query details. Owner and disposition: unassigned; review pending.

12 FRX GET /static/<path:filename>



Request Asset relative path (Data Flow)

Description:

Caller inputs cross the service boundary. Authority must be established independently of supplied identifiers. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Repeated requests exhaust service capacity

Denial of service, Open, Low Priority

Description:

Preconditions: A caller can repeatedly reach this interface; normal protected operations require a session. Assets: Local service availability. Consequences: Request work could delay report review, especially when file, database or provider work shares capacity. Architecture constraints: Loopback exposure and bounded portal request bodies limit some inputs; rate limits and capacity guarantees are unverified. Basis: REQ-04, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define request/concurrency budgets and ensure advisory-provider failure does not prevent report review. Verification plan: Use an agreed bounded load profile and provider-failure scenarios. Owner and disposition: unassigned; review pending.

Response Public asset / not found (Data Flow)

Description:

Return the endpoint result or error. An acknowledgement does not imply an out-of-scope workflow. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Public content or service response substituted

Tampering, Open, Low Priority

Description:

Preconditions: An attacker controls the local endpoint, delivery path or content source. Assets: Page, asset, status or metric integrity. Consequences: Altered content could mislead users or change browser behavior. Architecture constraints: Local-only service exposure; public responses are intentionally nonsecret. Host and delivery integrity are unverified. Basis: ARC-01, ARC-03, ARC-06, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Protect content publication and service identity; validate external responses before use. Verification plan: Review content-write permissions and test substituted responses in a disposable environment. Owner and disposition: unassigned; review pending.

Public asset bytes (Data Flow)

Description:

Read public browser assets if present. This is not upload retrieval. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Stored content altered outside the request policy

Tampering, Open, Medium Priority

Description:

Preconditions: An attacker has write access to this local resource. Assets: Public web assets. Consequences: Changes could corrupt reports, intake, browser assets or audit evidence, depending on the resource. Architecture constraints: Local storage is part of the architecture; separate permissions or protection zones are not assumed. Basis: REQ-02, REQ-03, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Restrict writes to authorized functions, protect published assets and verify integrity/recovery controls. Verification plan: Review access rights and test unauthorized modification and recovery. Owner and disposition: unassigned; review pending.

Browser / API client (External Actor)

Description:

Untrusted local caller. Partner, analyst and administrator roles matter where authenticated authority is required. Public operations accept anonymous callers. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

No threats listed.

FRX Public web assets (Process)

Description:

Serve public browser assets. This is not an intake-file retrieval interface. Basis: ARC-06 STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves.

Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Repeated requests exhaust service capacity

Denial of service, Open, Low Priority

Description:

Preconditions: A caller can repeatedly reach this interface; normal protected operations require a session. Assets: Local service availability. Consequences: Request work could delay report review, especially when file, database or provider work shares capacity. Architecture constraints: Loopback exposure and bounded portal request bodies limit some inputs; rate limits and capacity guarantees are unverified. Basis: REQ-04, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define request/concurrency budgets and ensure advisory-provider failure does not prevent report review. Verification plan: Use an agreed bounded load profile and provider-failure scenarios. Owner and disposition: unassigned; review pending.

Public web assets (Data Store)

Description:

Local resource accessed directly by FRX; no independently enforced storage zone is asserted. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Stored content altered outside the request policy

Tampering, Open, Medium Priority

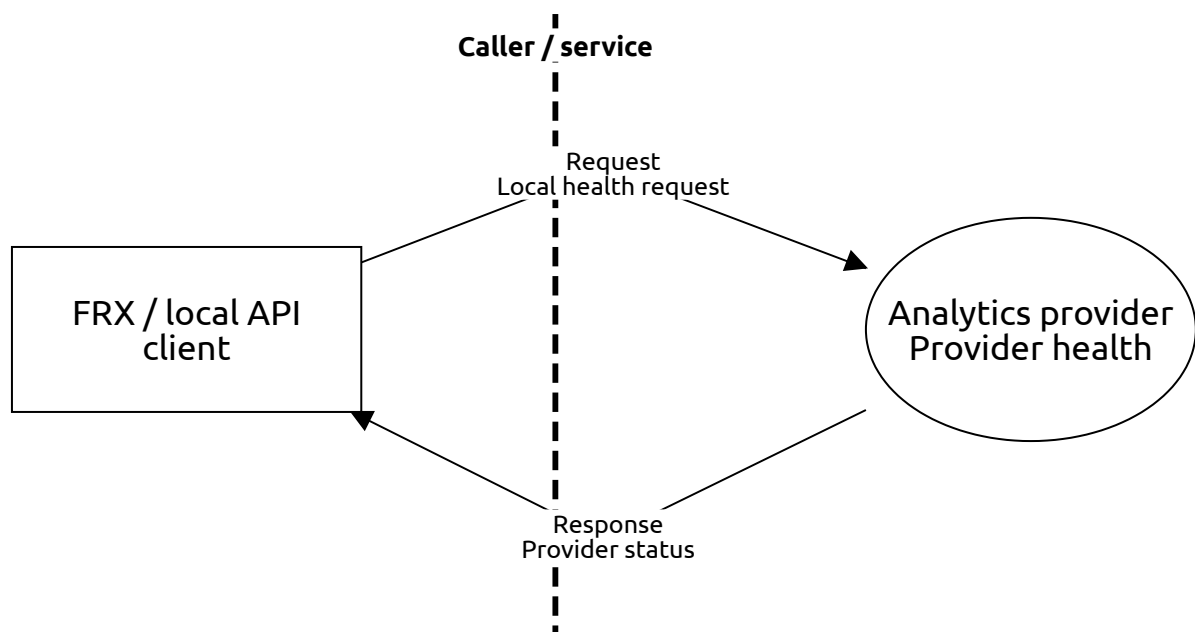
Description:

Preconditions: An attacker has write access to this local resource. Assets: Public web assets. Consequences: Changes could corrupt reports, intake, browser assets or audit evidence, depending on the resource. Architecture constraints: Local storage is part of the architecture; separate permissions or protection zones are not assumed. Basis: REQ-02, REQ-03, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Restrict writes to authorized functions, protect published assets and verify integrity/recovery controls. Verification plan: Review access rights and test unauthorized modification and recovery. Owner and disposition: unassigned; review pending.

13 Analytics provider GET /health



Request Local health request (Data Flow)

Description:

Caller inputs cross the service boundary. Authority must be established independently of supplied identifiers. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Repeated requests exhaust service capacity

Denial of service, Open, Low Priority

Description:

Preconditions: A caller can repeatedly reach this interface; normal protected operations require a session. Assets: Local service availability. Consequences: Request work could delay report review, especially when file, database or provider work shares capacity. Architecture constraints: Loopback exposure and bounded portal request bodies limit some inputs; rate limits and capacity guarantees are unverified. Basis: REQ-04, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define request/concurrency budgets and ensure advisory-provider failure does not prevent report review. Verification plan: Use an agreed bounded load profile and provider-failure scenarios. Owner and disposition: unassigned; review pending.

Response Provider status (Data Flow)

Description:

Return the endpoint result or error. An acknowledgement does not imply an out-of-scope workflow. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Public content or service response substituted

Tampering, Open, Low Priority

Description:

Preconditions: An attacker controls the local endpoint, delivery path or content source. Assets: Page, asset, status or metric integrity. Consequences: Altered content could mislead users or change browser behavior. Architecture constraints: Local-only service exposure; public responses are intentionally nonsecret. Host and delivery integrity are unverified. Basis: ARC-01, ARC-03, ARC-06, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Protect content publication and service identity; validate external responses before use. Verification plan: Review content-write permissions and test substituted responses in a disposable environment. Owner and disposition: unassigned; review pending.

FRX / local API client (External Actor)

Description:

Untrusted local caller. Partner, analyst and administrator roles matter where authenticated authority is required. Public operations accept anonymous callers. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

No threats listed.

Analytics provider Provider health (Process)

Description:

Return public local provider status, without a report lookup. Basis: ARC-03 STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Repeated requests exhaust service capacity

Denial of service, Open, Low Priority

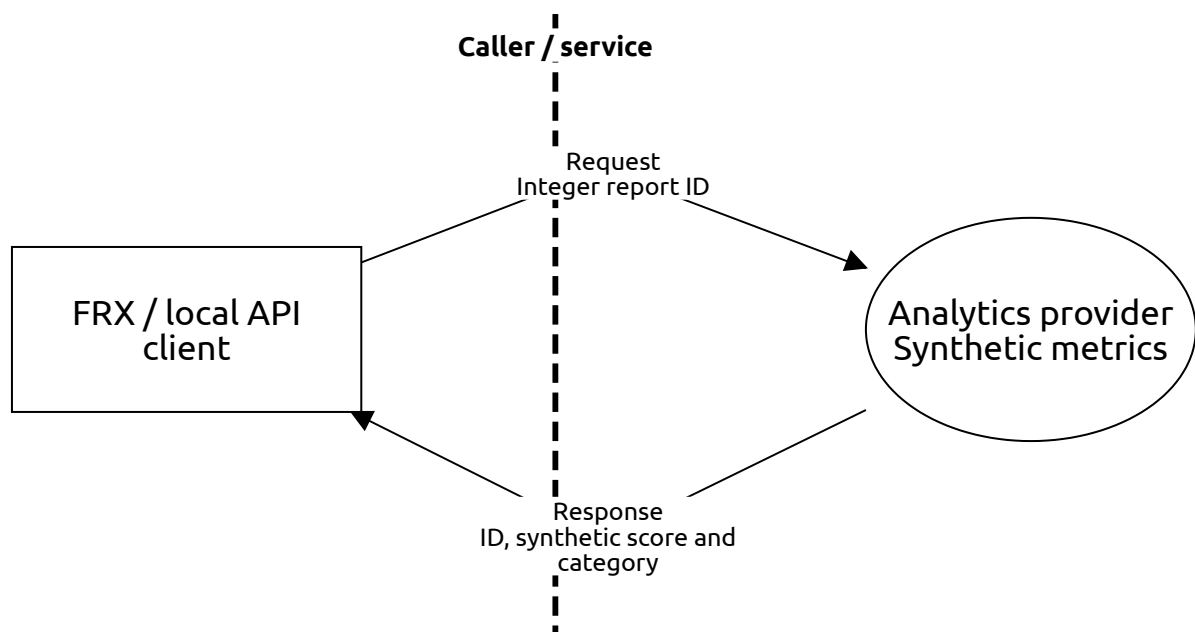
Description:

Preconditions: A caller can repeatedly reach this interface; normal protected operations require a session. Assets: Local service availability. Consequences: Request work could delay report review, especially when file, database or provider work shares capacity. Architecture constraints: Loopback exposure and bounded portal request bodies limit some inputs; rate limits and capacity guarantees are unverified. Basis: REQ-04, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define request/concurrency budgets and ensure advisory-provider failure does not prevent report review. Verification plan: Use an agreed bounded load profile and provider-failure scenarios. Owner and disposition: unassigned; review pending.

14 Analytics provider GET /metrics/<int:report_id>



Request Integer report ID (Data Flow)

Description:

Caller inputs cross the service boundary. Authority must be established independently of supplied identifiers. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Repeated requests exhaust service capacity

Denial of service, Open, Low Priority

Description:

Preconditions: A caller can repeatedly reach this interface; normal protected operations require a session. Assets: Local service availability. Consequences: Request work could delay report review, especially when file, database or provider work shares capacity. Architecture constraints: Loopback exposure and bounded portal request bodies limit some inputs; rate limits and capacity guarantees are unverified. Basis: REQ-04, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define request/concurrency budgets and ensure advisory-provider failure does not prevent report review. Verification plan: Use an agreed bounded load profile and provider-failure scenarios. Owner and disposition: unassigned; review pending.

Response ID, synthetic score and category (Data Flow)

Description:

Return the endpoint result or error. An acknowledgement does not imply an out-of-scope workflow. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Public content or service response substituted

Tampering, Open, Low Priority

Description:

Preconditions: An attacker controls the local endpoint, delivery path or content source. Assets: Page, asset, status or metric integrity. Consequences: Altered content could mislead users or change browser behavior. Architecture constraints: Local-only service exposure; public responses are intentionally nonsecret. Host and delivery integrity are unverified. Basis: ARC-01, ARC-03, ARC-06, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Protect content publication and service identity; validate external responses before use. Verification plan: Review content-write permissions and test substituted responses in a disposable environment. Owner and disposition: unassigned; review pending.

FRX / local API client (External Actor)

Description:

Untrusted local caller. Partner, analyst and administrator roles matter where authenticated authority is required. Public operations accept anonymous callers. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

No threats listed.

Analytics provider Synthetic metrics (Process)

Description:

Compute advisory synthetic metrics for an integer identifier. No report database connection, existence check or portal access decision is implied. Basis: REQ-04, ARC-03 STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Repeated requests exhaust service capacity

Denial of service, Open, Low Priority

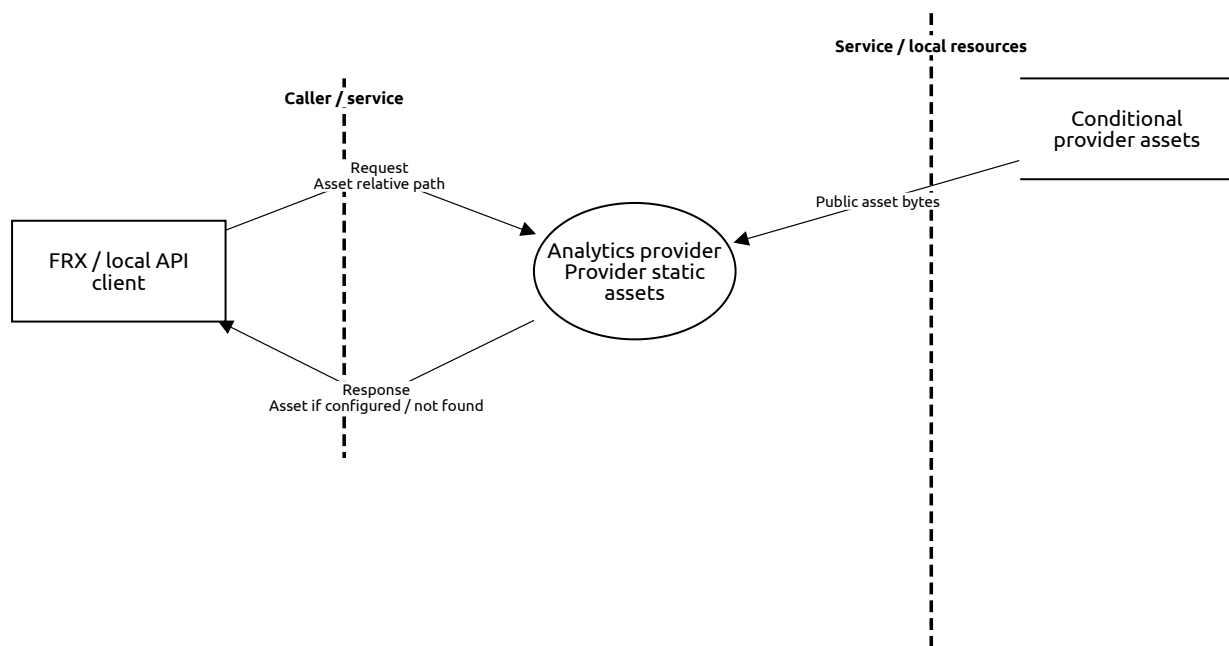
Description:

Preconditions: A caller can repeatedly reach this interface; normal protected operations require a session. Assets: Local service availability. Consequences: Request work could delay report review, especially when file, database or provider work shares capacity. Architecture constraints: Loopback exposure and bounded portal request bodies limit some inputs; rate limits and capacity guarantees are unverified. Basis: REQ-04, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define request/concurrency budgets and ensure advisory-provider failure does not prevent report review. Verification plan: Use an agreed bounded load profile and provider-failure scenarios. Owner and disposition: unassigned; review pending.

15 Analytics provider GET /static/<path:filename>



Request Asset relative path (Data Flow)

Description:

Caller inputs cross the service boundary. Authority must be established independently of supplied identifiers. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Repeated requests exhaust service capacity

Denial of service, Open, Low Priority

Description:

Preconditions: A caller can repeatedly reach this interface; normal protected operations require a session. Assets: Local service availability. Consequences: Request work could delay report review, especially when file, database or provider work shares capacity. Architecture constraints: Loopback exposure and bounded portal request bodies limit some inputs; rate limits and capacity guarantees are unverified. Basis: REQ-04, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define request/concurrency budgets and ensure advisory-provider failure does not prevent report review. Verification plan: Use an agreed bounded load profile and provider-failure scenarios. Owner and disposition: unassigned; review pending.

Response Asset if configured / not found (Data Flow)

Description:

Return the endpoint result or error. An acknowledgement does not imply an out-of-scope workflow. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Public content or service response substituted

Tampering, Open, Low Priority

Description:

Preconditions: An attacker controls the local endpoint, delivery path or content source. Assets: Page, asset, status or metric integrity. Consequences: Altered content could mislead users or change browser behavior. Architecture constraints: Local-only service exposure; public responses are intentionally nonsecret. Host and delivery integrity are unverified. Basis: ARC-01, ARC-03, ARC-06, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Protect content publication and service identity; validate external responses before use. Verification plan: Review content-write permissions and test substituted responses in a disposable environment. Owner and disposition: unassigned; review pending.

Public asset bytes (Data Flow)

Description:

Read public browser assets if present. This is not upload retrieval. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Stored content altered outside the request policy

Tampering, Open, Medium Priority

Description:

Preconditions: An attacker has write access to this local resource. Assets: Conditional provider assets. Consequences: Changes could corrupt reports, intake, browser assets or audit evidence, depending on the resource. Architecture constraints: Local storage is part of the architecture; separate permissions or protection zones are not assumed. Basis: REQ-02, REQ-03, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Restrict writes to authorized functions, protect published assets and verify integrity/recovery controls. Verification plan: Review access rights and test unauthorized modification and recovery. Owner and disposition: unassigned; review pending.

FRX / local API client (External Actor)

Description:

Untrusted local caller. Partner, analyst and administrator roles matter where authenticated authority is required. Public operations accept anonymous callers. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

No threats listed.

Analytics provider Provider static assets (Process)

Description:

Framework-provided static route; no provider asset directory is supplied for repository-root launch. A differently configured launch directory may expose its static files. Basis: ARC-03, ARC-06, ASM-01 STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: No separate modification mechanism beyond the associated processing, data-flow and storage scenarios. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: Applicable: attached scenario. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Repeated requests exhaust service capacity

Denial of service, Open, Low Priority

Description:

Preconditions: A caller can repeatedly reach this interface; normal protected operations require a session. Assets: Local service availability. Consequences: Request work could delay report review, especially when file, database or provider work shares capacity. Architecture constraints: Loopback exposure and bounded portal request bodies limit some inputs; rate limits and capacity guarantees are unverified. Basis: REQ-04, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Define request/concurrency budgets and ensure advisory-provider failure does not prevent report review. Verification plan: Use an agreed bounded load profile and provider-failure scenarios. Owner and disposition: unassigned; review pending.

Conditional provider assets (Data Store)

Description:

Conditional static directory; no dedicated provider assets supplied for the usual launch location. STRIDE applicability: Spoofing: No independent identity decision here; identity risks belong to the caller/session or provider relationship. Public callers need not identify themselves. Tampering: Applicable: attached scenario. Repudiation: No independent attributable action promised here; audit requirements are assessed on relevant operations and event storage. Information disclosure: No distinct protected disclosure beyond the associated private flows and stores; public assets and synthetic status/metrics are intentionally nonsecret. Denial of service: No independent exhaustion mechanism beyond service capacity and storage availability assessed on connected components. Elevation of privilege: No separate authority grant here; session and report policy are assessed at their decision points. Import performs no report update or payload execution.

Stored content altered outside the request policy

Tampering, Open, Medium Priority

Description:

Preconditions: An attacker has write access to this local resource. Assets: Conditional provider assets. Consequences: Changes could corrupt reports, intake, browser assets or audit evidence, depending on the resource. Architecture constraints: Local storage is part of the architecture; separate permissions or protection zones are not assumed. Basis: REQ-02, REQ-03, ARC-01, ASM-01. Verification status: planning scenario; not tested.

Mitigation:

Proposed controls: Restrict writes to authorized functions, protect published assets and verify integrity/recovery controls. Verification plan: Review access rights and test unauthorized modification and recovery. Owner and disposition: unassigned; review pending.